Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет информационных технологий и компьютерной безопасности
Кафедра систем информационной безопасности
Направление подготовки (специальность) 10.05.03 Информационная безопасность автоматизированных систем
(код и наименование направления подготовки)
Профиль/программа/направленность Обеспечение информационной безопасности распределённых информационных систем

ВЫПУСКНАЯ КВАЛИФИКАЦИОННАЯ РАБОТА

Дипломная работа
(вид выпускной квалификационной работы – бакалаврская работа, дипломная работа (проект), магистерская диссертация)
Харламова Никиты Сергеевича
(фамилия, имя, отчество обучающегося)

Тема: Управление рисками успешности реализации кибератак: информационное и методическое обеспечение

Состав выпускной квалификационной работы:

Расчетно-пояснительная записка на 91 страницах
Графическая часть на _____ листах

Расчетно-пояснительная записка к выпускной квалификационной работе:

Заведующий кафедрой _____ (А.Г. Остапенко)
(подпись) (инициалы, фамилия)

Руководитель _____ (А.С. Нахомова)
(подпись) (инициалы, фамилия)

Консультанты:
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

Обучающийся _____ Н.С. Харламов
(подпись) (инициалы, фамилия)

«02» 07 2025 г.

Министерство науки и высшего образования Российской Федерации

Федеральное государственное бюджетное образовательное учреждение высшего образования

«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»

(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет информационных технологий и компьютерной безопасности

Кафедра систем информационной безопасности

Направление подготовки/специальность 10.05.03 Информационная безопасность автоматизированных систем

(код, наименование)

Профиль/программа/направленность Обеспечение информационной безопасности распределённых информационных систем

Утверждаю _____

(дата)

Зав.кафедрой _____

(подпись)

ЗАДАНИЕ
ПО ПОДГОТОВКЕ ВЫПУСКНОЙ КВАЛИФИКАЦИОННОЙ РАБОТЫ

Дипломная работа

дипломная работа (проект), бакалаврская работа, магистерская диссертация

Обучающемуся Харламову Никите Сергеевичу

фамилия, имя, отчество

1. Тема: Управление рисками успешности реализации кибератак: информационное и методическое обеспечение

ФГБОУ ВО «ВГТУ», ВГТУ

по заданию какой организации выполняется работа

приказ №01-1-10/3-2979 от 25.06.2025

утверждена приказом по университету

2. Срок сдачи обучающимся выпускной квалификационной работы 02.07.25

3. Исходные данные

4. Краткое содержание выпускной квалификационной работы

Раздел 1 Исследование предметной области

перечень подлежащих разработке в выпускной квалификационной работе вопросов

Раздел 2 Применение дискретных распределений для оценки и регулирования рисками

Раздел 3 Разработка методик регулирования рисков с использованием выбранных распределений

5. Перечень графического материала (с точным указанием обязательных чертежей по разделам

6. Консультанты (с указанием относящихся к ним разделов)

График выполнения выпускной квалификационной работы

№ п/п	Наименование разделов выпускной квалификационной работы	Срок выполнения этапов работы
1	Введение	22.03 - 22.05
2	Исследование предметной области	22.03 - 22.05
3	Применение дискретных распределений для оценки и регулирования рисками	23.05 - 31.05
4	Разработка методик регулирования рисков с использованием выбранных распределений	01.06 - 24.06
5	Заключение	25.06 - 02.07

Руководитель _____
(подпись)

Дата выдачи задания 22.03.25

Задание принял к исполнению 22.03.25
(дата)

Подпись обучающегося _____

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»

АННОТАЦИЯ
выпускной квалификационной работы

Обучающегося Харламова Никиты Сергеевича

Тема ВКР: Управление рисками успешности реализации кибератак: информационное и методическое обеспечение

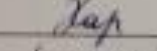
Характеристика выпускной квалификационной работы

Актуальность исследования: Современные подходы к управлению рисками ИБ требуют не только оценки, но и активного регулирования рисков с учетом динамики изменения параметров угроз и ресурсов системы. Разработка методик и алгоритмов, позволяющих адаптивно изменять параметры модели с целью удержания риска в допустимых пределах, представляет собой перспективное направление научных исследований и практического применения.

Задачи, решаемые в ВКР: собрать и систематизировать информацию о существующих подходах и методах управления рисками реализации кибератак на основе анализа интернет-источников; разработать методику обоснованного выбора дискретных распределений для оценки и управления рисками ИБ, в зависимости от проектных условий и случайных процессов; предложить методики регулирования рисков в нужных диапазонах ущерба, позволяющие адаптивно корректировать параметры риска для повышения устойчивости системы, для выбранных дискретных распределений.

Структура ВКР: исследование предметной области; применение дискретных распределений для оценки и регулирования рисками; разработка методик регулирования рисков с использованием выбранных распределений.

Краткая характеристика полученных результатов: собрана и систематизирована информация о существующих подходах и методах управления рисками реализации кибератак на основе анализа интернет-источников; разработана методика обоснованного выбора дискретных распределений для оценки и управления рисками ИБ, в зависимости от проектных условий и случайных процессов; предложены методики регулирования рисков в нужных диапазонах ущерба, позволяющие адаптивно корректировать параметры риска для повышения устойчивости системы, для выбранных дискретных распределений.

Автор ВКР  Харламов Никита Сергеевич
(подпись)

СОДЕРЖАНИЕ

Введение 6
1 Исследование предметной области 11
1.1 Риски и неопределенность: базовые принципы и их применение в ИБ 11
1.2 Особенности процесса управления рисками 15
2 Применение дискретных распределений для оценки и регулирования рисками 30
2.1 Анализ дискретных распределений для задач управления рисками в ИБ 30
2.1.1 Биномиальное распределение 30
2.1.2 Мультиномиальное распределение 32
2.1.3 Гипергеометрическое распределение 34
2.1.4 Геометрическое распределение 35
2.1.5 Распределение Паскаля 37
2.1.6 Распределение Пуассона 38
2.2 Выбор дискретного распределения 39
3 Разработка методик регулирования рисков с использованием выбранных распределений 41
3.1 Регулирование риска с использованием биномиального распределения 41
3.1.1 Обоснование выбора биномиального распределения и выбор регулируемого параметра 41
3.1.2 Методика регулирования риска с использованием биномиального распределения 46
3.2 Регулирование риска с использованием гипергеометрического распределения 58
3.2.1 Обоснование выбора гипергеометрического распределения и выбор регулируемого параметра 58
3.2.2 Методика регулирования риска с использованием гипергеометрического распределения 61
Заключение 76
Список литературы 78

ВВЕДЕНИЕ

Проблема безопасности киберпространства [1-9] неуклонно возрастает по своей актуальности, так как только в Российской Федерации наблюдаются следующие тенденции:

– рост количества инцидентов информационной безопасности на 15% по сравнению с прошлым годом, уменьшение на 4% по сравнению с предыдущим кварталом;

– рост количества утечек персональных данных, таких как телефонные номера, email адреса пользователей на 70%, где на отрасль электронной коммерции приходится 38%, на сегмент развлекательных ресурсов – 8%, на сектор медицины – 7%

– рост количества заказных кибератак до 44%.

При этом:

– ВПО является и остается одним из основных инструментов, используемым в 66% атак на организации и 51% на частных лиц;

– 42% составляют атаки с использованием шифровальщиков;

– 48% составляют атаки с использованием шпионского ПО на частных лиц.

Убытки организаций в результате успешной реализации атак составляют более 100 млрд рублей. При этом наблюдается тенденция роста этой цифры. Дополнительный ущерб приносят угрозы, основанные на человеческом факторе, сбоях, возникающих на оборудовании. Сами данные о возникающих инцидентах не являются достоверными ввиду того, около 80% остаются неизвестными, поскольку организации предпочитают скрывать информацию о понесенном ущербе, чтобы избежать возникновения репутационных или иных рисков [10-11].

Целью реализации кибератак является – получение сведений, которые можно продать или использовать для реализации новой серии атак, похищение денежных средств. Выявить злоумышленника в глобальной сети практически не представляется возможным. Поэтому понятия «100%-я безопасность» не существует, поскольку нет таких систем безопасности, которые могут её абсолютно гарантировать абсолютную.

Ввиду невозможности обеспечения 100% безопасности организация работает над тем, чтобы снизить риск возникновения критичных ситуаций. Поэтому процесс управления рисками выступает связующим звеном между анализом угроз и принятием решений, обеспечивая как стратегическую устойчивость, так и оперативную адаптацию. Его роль особенно важна в сфере информационной безопасности, где неопределенность и потенциальные потери требуют математически обоснованного и систематического подхода.

В эпоху интенсивного развития цифровых технологий и роста числа киберугроз без исключения каждая организация желает понять, сколько она инвестирует в кибербезопасность и окупает ли результат этих вложений. Кибербезопасность требует больших вложений и грамотного подхода для эффективного управления рисками и оценки отдачи от этих инвестиций.

Изученные в рамках исследования аналоги направленны на анализ и оценку рисков кибератак [12-14], разработку методик для снижения рисков [12, 13, 16-18], регулирование и минимизацию рисков [13, 15, 16, 18], интеграцию стандартов и нормативных требований [15, 17]. Общим объектом исследования являются риски информационной безопасности, связанные с реализацией кибератак, включая массированные атаки, эксплуатацию уязвимостей и угрозы. Проведенное исследование аналогов [12-18] позволяет предложить следующее целеполагание настоящего исследования.

Объект исследования: процесс управления рисками реализации кибератак в информационной системе.

Предмет исследования: методы математического моделирования и управления рисками информационной безопасности на основе вероятностных распределений.

Целью исследования является повышение защищенности систем и сетей за счет создания инструментария регулирования рисков на основе дискретных распределений.

Актуальность исследования обусловлена рядом **противоречий** между:

– объективной потребностью в универсальной структуре процесса управления рисками, способной охватывать широкий спектр угроз, и разнообразием практических сценариев реализации кибератак, делающих применение унифицированного подхода затруднительным;

– спецификой практических ситуаций, определяющих форму распределения риска, и необходимостью универсального выбора вероятностной модели для формализации угроз;

– стохастической природой риска, зависящей от параметров дискретного распределения, и необходимостью удерживать его на нужном уровне для обеспечения безопасности системы;

Для разрешения выявленных противоречий и достижения поставленной цели необходимо решить следующие **задачи:**

– собрать и систематизировать информацию о существующих подходах и методах управления рисками реализации кибератак на основе анализа интернет-источников;

– разработать методику обоснованного выбора дискретных распределений для оценки и управления рисками ИБ, в зависимости от проектных условий и случайных процессов;

– предложить методики регулирования рисков в нужных диапазонах ущерба, позволяющие адаптивно корректировать параметры риска для повышения устойчивости системы, для выбранных дискретных распределений.

На защиту выносятся следующие **результаты:**

– собрана и систематизирована информация о существующих подходах и методах управления рисками реализации кибератак на основе анализа интернет-источников;

– разработана методика обоснованного выбора дискретных распределений для оценки и управления рисками ИБ, в зависимости от проектных условий и случайных процессов;

– предложены методики регулирования рисков в нужных диапазонах ущерба, позволяющие адаптивно корректировать параметры риска для повышения устойчивости системы, для выбранных дискретных распределений.

Новизна полученных результатов заключается в следующем:

– впервые предложен структурированный подход к систематизации знаний в области управления рисками, позволяющий динамически обновлять базу подходов и практик;

– впервые разработана методика, позволяющая обосновать и формализовать выбор нужного распределения в зависимости от рассматриваемой задачи, типа случайного процесса и статистических свойств;

– впервые предложены методики регулирования рисков в нужных диапазонах ущерба, позволяющие адаптивно корректировать параметры риска для повышения устойчивости системы, для выбранных дискретных распределений.

Теоретическая значимость:

– систематизация информации по существующим подходам и методам управления рисками позволит расширить и структурировать существующие знания в области управления рисками информационной безопасности, сформировать основу для построения математических моделей, учитывающих вероятностный характер угроз;

– развитие методического аппарата в обосновании выбора и применения дискретных распределений в управлении рисками позволит усилить научную базу для построения адаптивных и формализованных моделей защиты;

– предложенные методики позволят более эффективно использовать дискретные вероятностные модели в задачах оценки и управления рисками успешности реализации кибератак.

Практическая значимость:

– систематизация информации на основе анализа открытых источников позволит разработать структурированную базу знаний о современных методах управления рисками, которую можно применить в аналитических центрах, при разработке нормативных документов;

– ситуационно-обоснованное применение дискретных распределений может помочь специалистам при принятии решений в процессе оценки и прогнозирования риска в условиях неопределенности и ограниченности данных;

– предложенные методики позволят более эффективно регулировать риски для дальнейшей оценки, позволяющей принять правильное решение и минимизировать ущерб.

1 Исследование предметной области

1.1 Риски и неопределенность: базовые принципы и их применение в ИБ

Управление рисками – быстро развивающаяся область, которая играет большую роль в разных областях науки, начиная с экономики и менеджмента, заканчивая производственными процессами. Каждой организации в данной деятельности необходимо иметь собственную стратегию по регулированию риска, чтобы повысить шансы в деятельности, связанной с прогнозированием, или снизить риск возникновения ущерба, который может быть нанесен репутации компании и её финансовому положению [19-24]. Графически зависимость вероятности возникновения ущерба от величины самого ущерба представлена на рисунке 1.

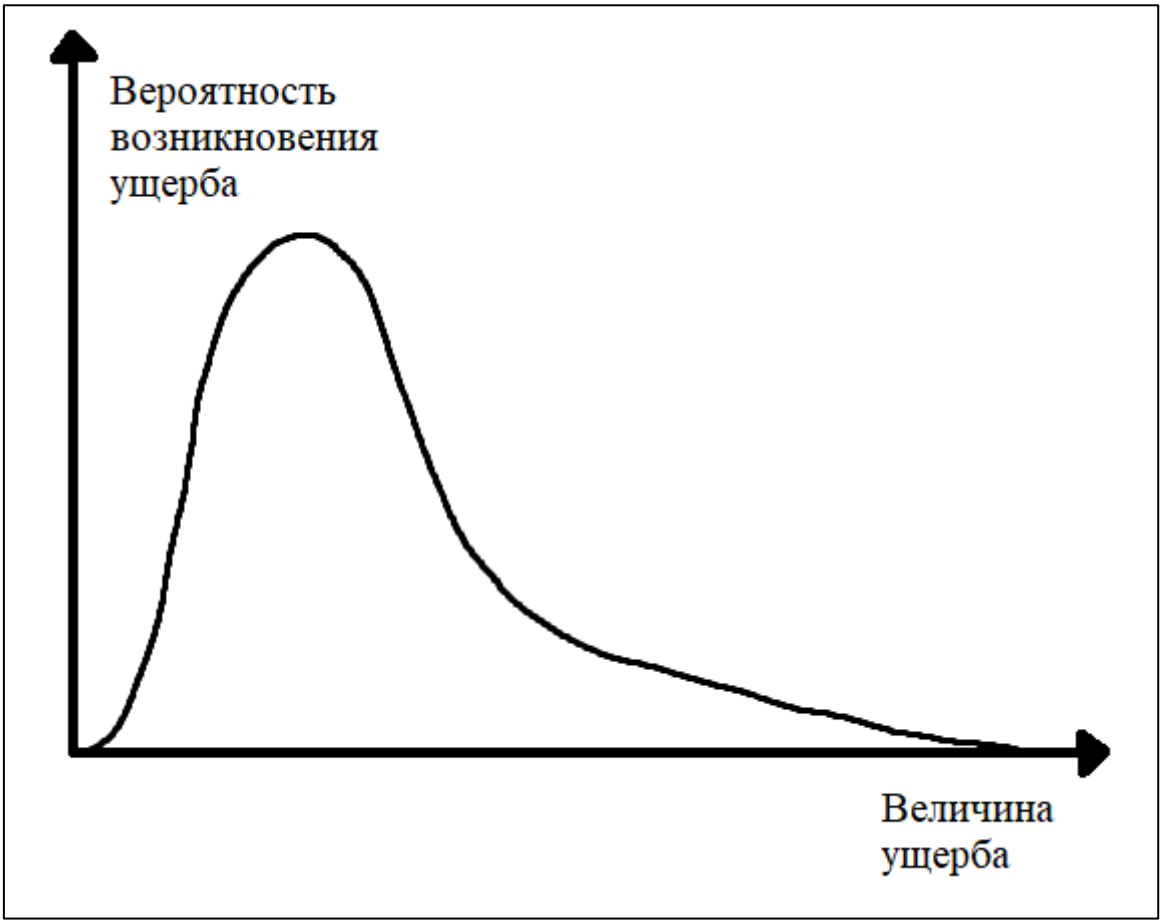


Рисунок 1 – Зависимость вероятности возникновения ущерба от величины ущерба

Методы управления рисками проникают во все быстро развивающиеся современные области науки. Их ценность заключается в снижении вероятности возникновения негативных ситуаций и их влияния на бизнес-процессы, поскольку риск существует везде, где есть неопределенность будущего. Риск тем выше, чем более многовариантно будущее. При наличии неопределенности и альтернатив риск – это возможность реализации худших альтернатив. Риск является мерой несоответствия между различными результатами решений. Их оценивают с точки зрения их полезности, а также эффективности по критериям соответствия, степенью неопределенности экономического результата в будущем [21-23].

Неопределенность можно оценить разными способами, начиная с количественных методов оценки и заканчивания прогнозированием. Соответственно для разных типов неопределенности будут использоваться разные методы учета – статистические, экспертные методы, методы предельных значений. Систематизация понятия неопределенности с методами её анализа представлена на рисунке 2.

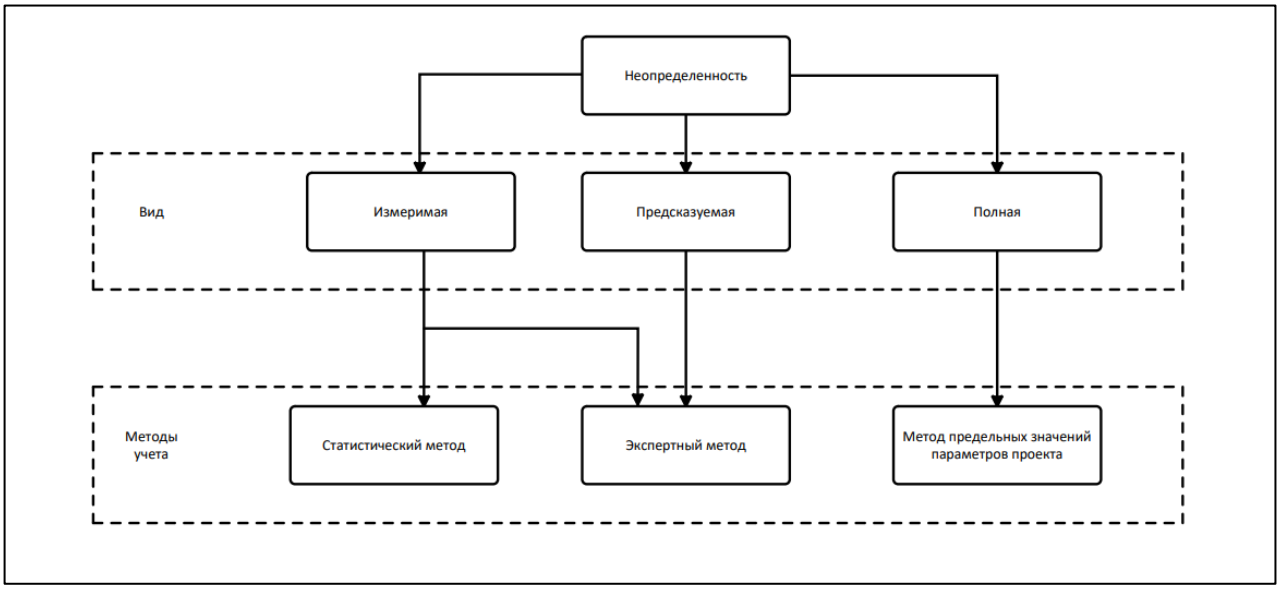


Рисунок 2 – Систематизация понятия неопределенности

Именно от степени неопределенности специалисты разных сфер отталкиваются при управлении рисков. Поэтому особое место управление рисками занимает в области информационной безопасности, когда количество инцидентов неуклонно

увеличивается с каждым годом, о чем может сказать разница в статистике за 2023 и 2024 года, которая представлена на рисунке 3 [25-26].

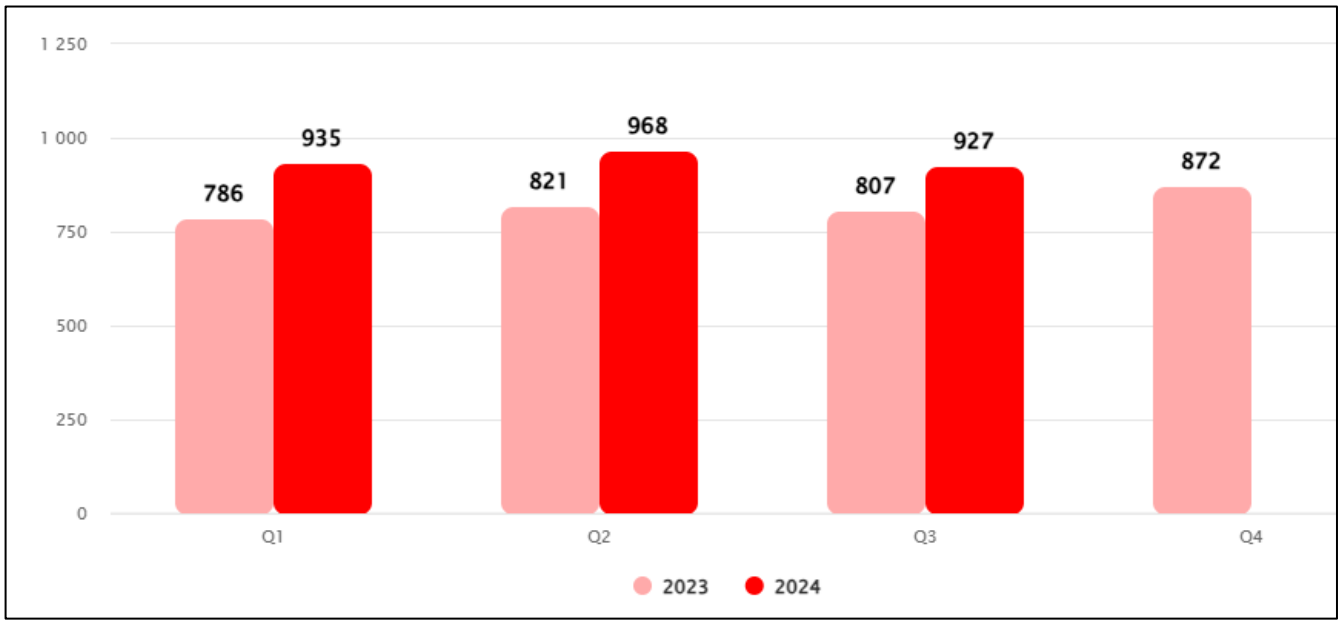


Рисунок 3 – Количество инцидентов ИБ по кварталам за 2023 и 2024 год

В области информационной безопасности управление рисками использует свой понятийный аппарат, который приведен в стандартах ГОСТ Р ИСО/МЭК 13335-1-2006, ГОСТ Р ИСО/МЭК 27001-2006, ГОСТ Р ИСО/МЭК 27005-2010 и других. Последний из них является руководством, приводящим общее концепции управления рисками ИБ. Весь процесс управления рисками направлен на:

– получение наиболее полного охвата возможных рисков, который позволит свести степень неопределенности до минимума;

– сведение этого охвата возможных рисков и степени их влияния на информационную систему к минимуму;

– быстрое реагирование на новые риски, появляющиеся в результате успешно-реализованных кибератак, на изменения, которые происходят при реализации этого риска;

– принятие риска [21-22].

Процесс управления рисками циклический, осуществляющийся на протяжении всего жизненного цикла, начиная с разработки, заканчивая непосредственной

эксплуатацией информационной системы. Поэтому вопрос: когда управлять имеет следующие ответы:

– при проектировании информационной системы – на данном этапе заранее необходимо выработать требования, которые позволили бы минимизировать уязвимости и возможные угрозы;

– при разработке информационной системы: необходимо выбрать конкретные аппаратные решения, программное обеспечение, имеющее меньшее количество уязвимостей, по сравнению с аналогами, имеющими тот же функционал;

– при установке и внедрении информационной системы: необходимо учитывать риски при конфигурировании оборудования и настройки ИС, осуществлять тестирование ИС с помощью имеющегося ПО или, пользуясь услугами пентестеров, чтобы не допустить появления новых уязвимостей или закрытия старых;

– при непосредственной эксплуатации: необходимо учитывать риски при существенных изменениях.

Процесс менеджмента риска ИБ состоит из установления контекста, оценки риска, обработки риска, принятия риска, коммуникаций риска, а также мониторинга и переоценки риска информационной безопасности [23-24]. Процесс менеджмента риска ИБ представлен на рисунке 4.

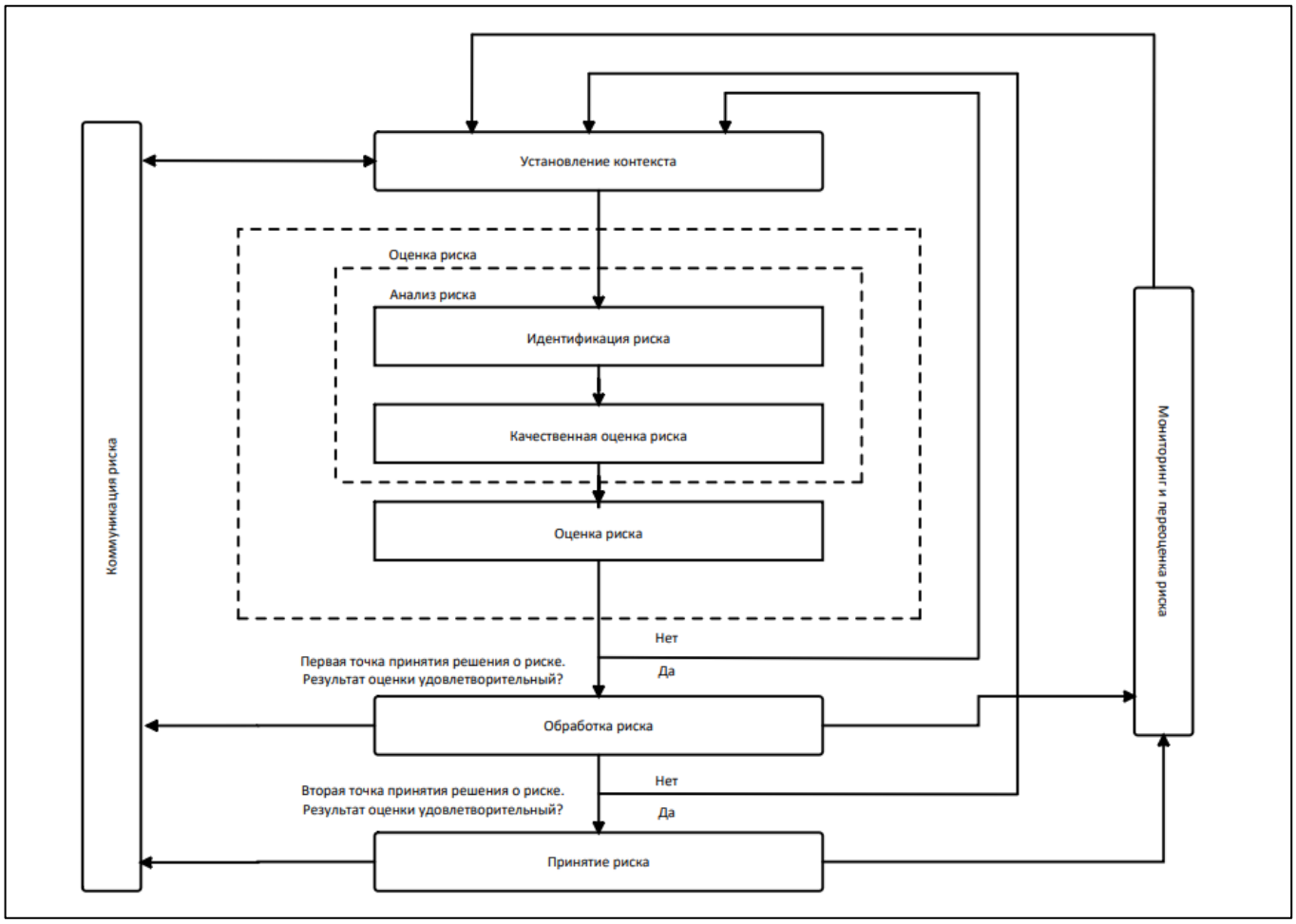


Рисунок 4 – Процесс менеджмента риска ИБ

1.2 Особенности процесса управления рисками

Управление рисками информационной безопасности (УР ИБ) – итеративный процесс, требующий постоянного контроля над непрерывно-меняющейся ситуацией. В зависимости от сферы деятельности, имеющихся активов и целей менеджмента риска могут использоваться различные подходы по управлению и оценке риска информационной безопасности [25].

Суть основных этапов менеджмента рисков остается неизменной, но в рамках разной постановки задач они могут корректироваться и уточняться. Так, эти этапы могут быть конкретизированы следующим образом:

– выбор анализируемых объектов: на данном этапе необходимо определить область применения процесса управления рисками, определяются организационные и технические ограничения;

– выбор методик оценки рисков подразумевает определение качественных и количественных методик, которые будут использоваться при оценке риска, шкал, математических принципов, используемых для оценки вероятности.

Качественные методики пользуются популярностью во многих технологически развитых странах ввиду их простоты и разработанности под международные стандарты. Наиболее известными методиками являются [27]:

а) COBRA позволяет осуществить самый простой способ оценки риска в автоматизированном режиме с помощью специализированных баз знаний и процедур, ориентированных на требования ISO 17799;

б) RA Software Tool также позволяет выполнить оценку рисков в соответствии с требованиями ISO 17799.

Количественные методики используются решения оптимизационных задач, где необходимо принять решение из перечня вариантов. Такие задачи основаны на выборе альтернатив с учетом в условиях ограниченности ресурсов. Самые известные количественные методики являются:

а) CRAMM, который является универсальным инструментом, позволяющим решать класс аудиторских задач, направленных на изучение ИС, её проверку на соответствие требованиям по информационной безопасности. Данный метод является объединением качественных и количественных методов анализа риска, обеспечивая тем самым комплексный подход. Одним из ключевых вопросов при реализации метода CRAMM, являются вопросы о необходимости проведения более детального анализа ввиду недостаточности базовых мер защиты, после чего осуществляется сама идентификация и оценка величины риска на основе анализа угроз и уязвимостей. Исходя из полученных данных принимается решение о выборе контрмер, технических или организационно-правовых;

б) RiskWatch является программным обеспечением и в то же время является мощным средством УР. Методика включает в себя 4 основных этапа – определение

предмета исследования (параметры системы, требования безопасности, каждое из которых необходимо подробно расписать), ввод данных в используемое программное обеспечение, оценка рисков на основе установления связи между ресурсами, угрозами и уязвимостями, генерация отчетов для получения детальной информации по выполненной операции. Отчеты позволят сделать дополнительный анализ, понять, как можно снизить риск в той или иной ситуации [27];

в) ГРИФ – отличается относительной простотой интерфейса в отличие от иностранных аналогов, но в то же время он учитывает огромное количество параметров, дающих возможность получить максимально точную оценку. Данный метод имеет несколько этапов: опрос с целью получения списка активов, опрос с целью ввода в базу данных ГРИФ всей информации, имеющую ценность для организации, определение групп пользователей и их число в каждой из них, в том числе распределение прав доступа между ними, опрос для определения СЗИ, использующимися для защиты ценных активов, анкетирование по политике безопасности;

г) OCTAVE заключается в оценке угроз, активов и уязвимостей, при этом для этого используется серия семинаров, на которых осуществляется планирование, координация действий. Однако в первую очередь на практике разрабатываются профили угроз, составляется перечень активов, уязвимостей, которые могут быть реализованы при некой угрозе. На основе полученной информации осуществляется оценка рисков ИБ, подразумевающая собой определение вероятности причинения ущерба при реализации угрозы ИБ через единичную или серию уязвимостей;

д) MITRE основан на использовании матрицы MITRE, позволяющей описать атаку злоумышленника на основе имеющихся тактик и техник.

Данные методики являются наиболее популярными и не теряют актуальности до сих пор;

– идентификация активов: данный этап включает в себя разработку перечня имеющихся активов, определить их ценность для компании, выделить те из них, которые представляют особую важность для организации;

– анализ угроз и их последствий, выявление уязвимых мест в защите: на данном этапе все начинается с обработки исходных данных, поскольку весь процесс управления рисками в самом начале разработки информационной системы опирается на построение модели угроз. Она является отправной точкой для изучения возможных рисков организации ввиду того, что модель угроз позволяет расписать сам риск, который складывается из угрозы, уязвимости и актива. Это позволяет понять какая угроза будет реализована, через какую уязвимость и на какой актив направлена. При этом исходными данными для модели угроз являются:

а) банк данных угроз ФСТЭК России;

б) документация на системы и сети;

в) описание шаблонов атак их открытых источников – CAPEC, MITRE;

г) описание критических процессов [28-33].

Модель угроз включает в себя следующие пункты, представленные на рисунке 5.

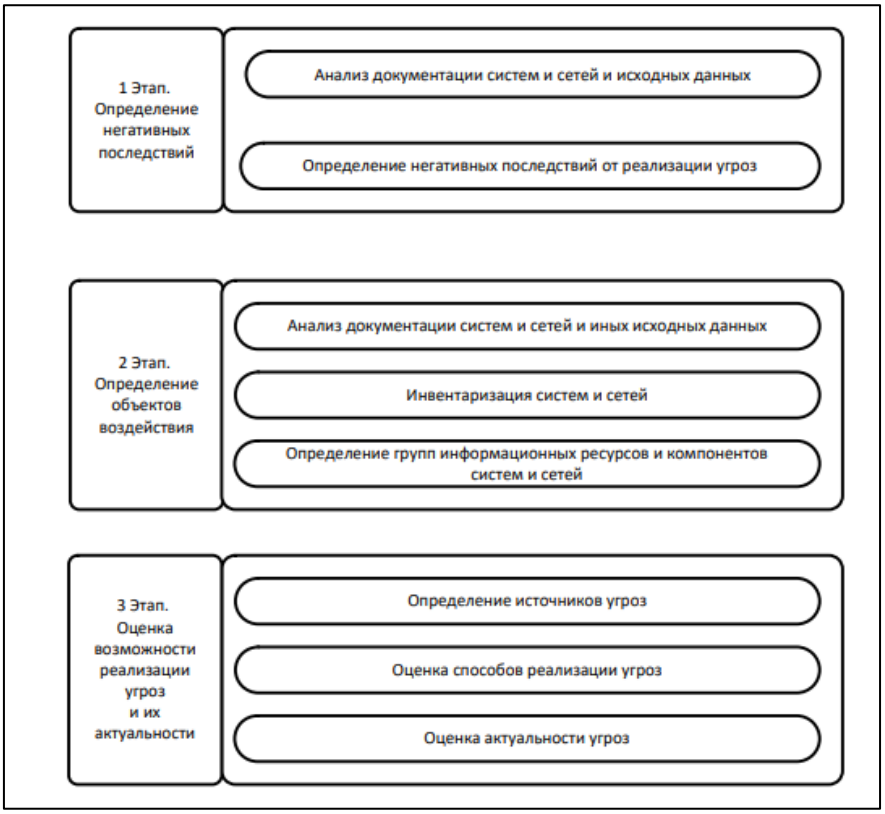


Рисунок 5 – Общая схема проведения оценки угроз безопасности информации

– оценка рисков является одним из центральных элементов процесса управления рисками ввиду того, что своевременное определение, обработка рисков позволяет своевременно снизить вероятность возникновения ущерба как репутационного, так и материального. На данном этапе все выявленные риски анализируются, определяется их потенциальное влияние, что является отправной точкой для принятия решений о дальнейших действиях по его регулированию или о выборе мер и необходимых средств защиты информации [34-37].

Как правило, при оценке рисков используются как качественные, так и количественные методики по управлению рисками. При качественном подходе не используются количественные или денежные выражения для объекта оценки. Для этого существует набор шкал, позволяющий проранжировать по трехбальной, пятибальной или десятибальной системе оценивания. Для ранжирования и используются проведение опросников, анкетирование, интервьюирование. Трудность в данном случае заключается в выборе сотрудника, который имеет соответствующий опыт проведения качественной оценки риска, компетенции в рассматриваемой области. На основе полученных результатов проведенных действий производится анализ, определяется «приемлемый уровень риска», который компания готова принять и из чего делается вывод о нецелесообразности дальнейшего внедрения средств защиты информации.

Если обращаться к инструментам количественного риск-менеджмента, то ключевую роль играют теоретико-вероятностные и статистические модели ввиду их наибольшей распространенности. Они позволяют описывать существенные стороны изучаемого процесса или явления в виде математических отношений, а затем анализировать их с помощью соответствующего математического аппарата. Модели имеют особую важность в сфере прогнозирования, изучения альтернатив, что позволяет специалисту численно оценить последствия принимаемых решений. Универсальной модели, подходящей под всевозможные ситуации, не существует ввиду множественности самих типов рисков и разнообразия механизмов их возникновения. Ввиду этих факторов создание такой модели просто не представляется возможным, поэтому каждая отдельная ситуация требует

использования специфических моделей, поскольку при её построении необходимо отталкиваться от свойств исследуемого, моделируемого объекта. Однако схожесть изучаемых ситуаций позволяет использовать некоторые аналоги инструментов и общие подходы к моделированию, за счет использования стохастических, дифференциальных уравнений, иного математического аппарата. В случае, если известны подходы к построению модели и получения результата, можно применить стандартные подходы [38-41].

В качестве математических методов могут использоваться:

а) базовые вероятностные модели: дискретные, непрерывные распределения, марковские процессы;

б) статистические методы оценки: метод Монте-Карло, анализ временных рядов;

в) теория экстремальных значений, направленная на анализ хвостов.

Проблемами количественных моделей могут быть осложнения, связанные с невозможностью учета неизвестных параметров и переменных, недостатком исторических данных по новым угрозам. Поэтому именно гибридные модели оценки риска, сочетающие статистически модели с экспертными оценками, позволят получить наибольший эффект [42-51].

Таким образом процесс оценки рисков можно представить следующим образом на рисунке 6.

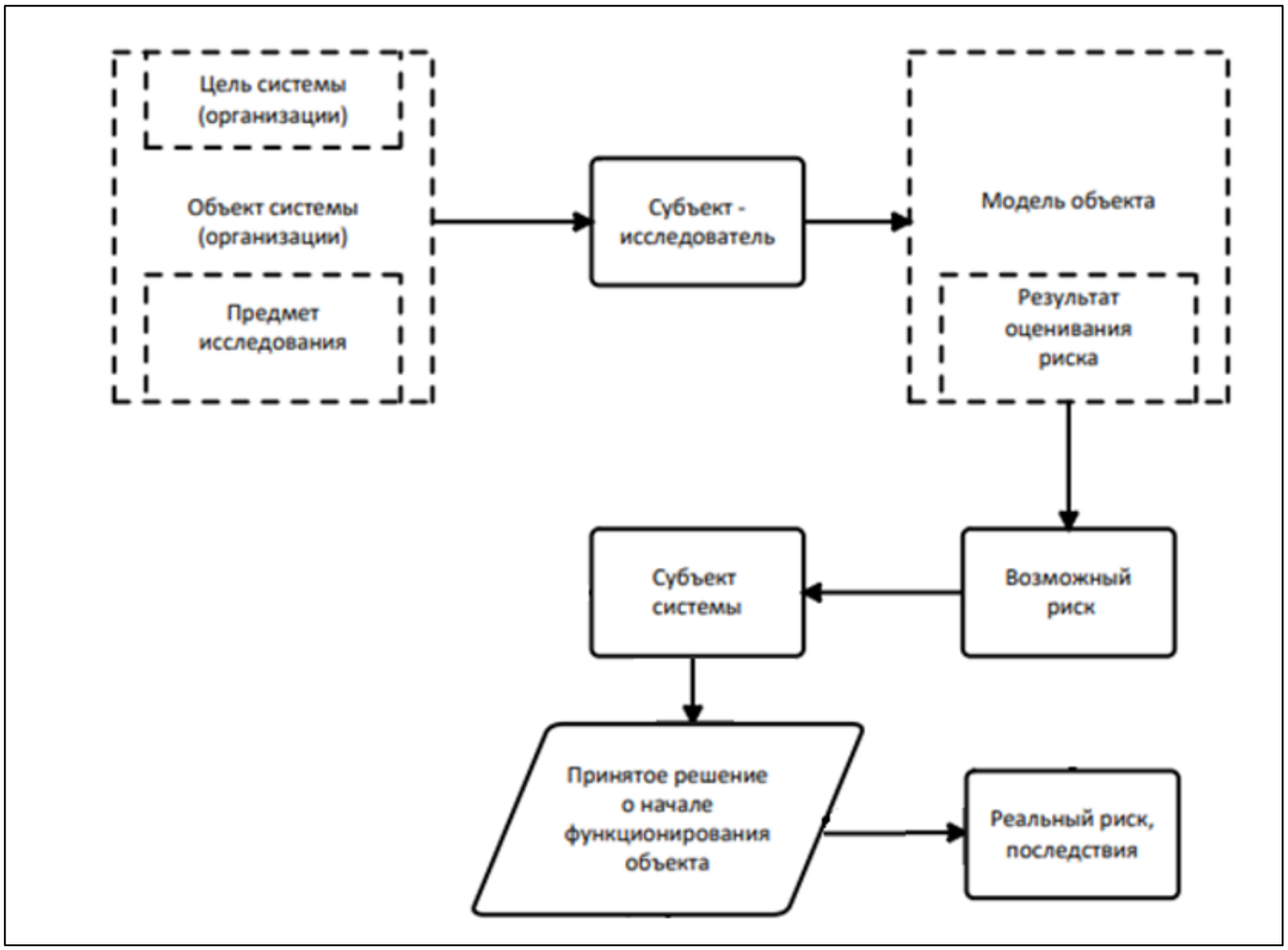


Рисунок 6 – Процесс оценки рисков

Помимо самого процесса оценки рисков не менее и важна классификация рисков. Полученные риски могут быть классифицированы по разным критериям:

а) по степени зависимости ущерба от исходного события:

1) первичные риски – риски, непосредственно связанные с неблагоприятным исходным событием, то есть ошибки в ведении учета, формировании документации, которые могут за собой повлечь иные риски и последствия;

2) вторичные риски – последствия первичного риска (репутационные, юридические, технические, операционные);

3) остаточные риски – риски, остающиеся после реализации всех защитных мер, при котором его дальнейшее снижение не имеет смысла [52-55];

4) несобытийные – угрозы, не зависящие от некоторого активатора (устаревание технологий);

б) классификация по размеру ущерба [56-63]:

1) малые риски – ущерб составляет меньше 10000$, характеризуется незначительным влиянием на бизнес;

2) средние риски – ущерб составляет от 10000$ до 1000000$, характеризуется заметными потерями, но без критических последствий;

3) высокие риски – ущерб составляет от 1M $ до 10M $, характеризуется серьезными финансовыми и репутационными потерями;

4) катастрофические риски – ущерб составляет более 10M $, характеризуется серьезными последствиями, при которых возникают угрозы существованию компании в виде полной остановки производства или банкротства;

в) по природе возникновения [56-63]:

1) технические – уязвимости программного обеспечения/оборудования;

2) человеческие – ошибки персонала, злонамеренные действия, подготовка для проведения атаки типа «социальная инженерия»;

3) природные (естественные) – стихийные бедствия;

4) организационные – проблемы политик безопасности или управленческих решений;

5) юридические – несоответствие законам, нормативно-правовым актом в области информационной безопасности;

6) искусственные – выражаются действием или бездействием людей, поэтому делятся на преднамеренные (злонамеренное причинение вреда из-за внешних угроз, таких как хакеры, и внутренних угроз в виде инсайдеров, недовольных сотрудников) и непреднамеренные (ошибки, небрежность или незнание сотрудников в виде неправильной настройки и потере устройств и/или разработчиков в виде наличия багов, уязвимостей в коде);

г) по вероятности реализации:

1) высокая – больше 70%;

2) средняя – от 30 до 70%;

3) низкая – менее 30%;

д) по расположению [56-63]:

1) внешние – отдельные хакеры, группировки и иные лица, находящиеся вне компании;

2) внутренние – лица, несущие угрозу внутри организации;

е) по времени воздействия:

1) кратковременные – от нескольких часов до нескольких дней;

2) среднесрочные – от нескольких недель до нескольких месяцев;

3) долгосрочные – несколько лет.

В процессе риск-менеджмента целесообразно комбинировать классификации, чтобы определить стратегии реагирования и впоследствии следить за динамикой;

– выбор защитных мер: обеспечение безопасности, должно основываться своевременном применении всего комплекса мер в соответствии с нормативно-правовыми актами и мнению специалистов, однако их необходимо соразмерять с возможностями самой организации и информационной системы [64-65].

Цель внедрения системы защиты информации – достижение соблюдения основных принципов информационной безопасности (обеспечение конфиденциальности, целостности, доступности информации). Многие активы представлены в виде информации, которая хранится, обрабатывается и передается продуктами ИТ таким образом, чтобы удовлетворить требования владельцев информации. Поэтому владельцы информации вправе требовать, чтобы доступность, распространение и модификация любой такой информации строго контролировались и активы были защищены от угроз. Рисунок 7 иллюстрирует высокоуровневые понятия безопасности и их взаимосвязь.

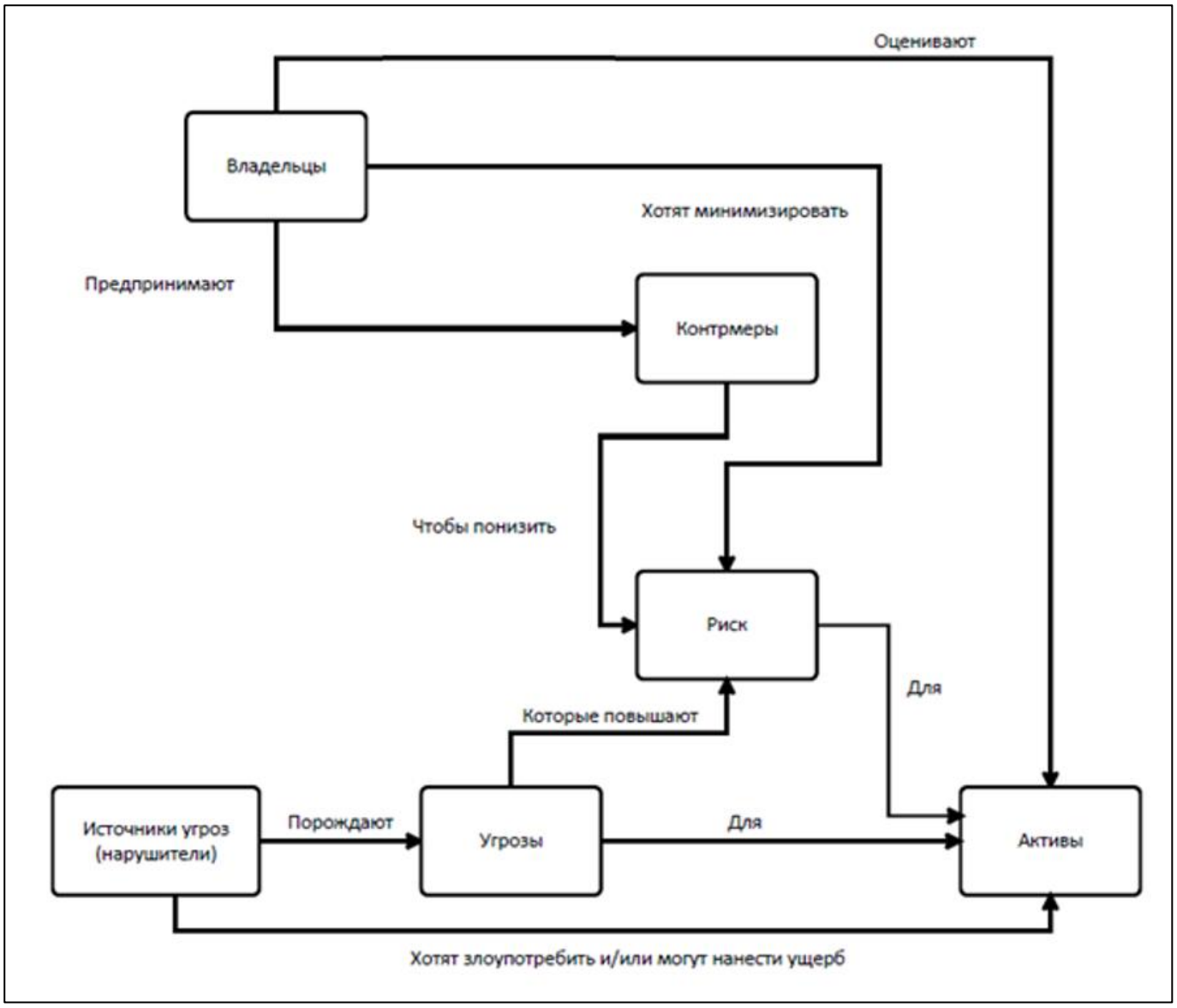


Рисунок 7 – Понятия безопасности и их взаимосвязь

Контрмеры реализуются для снижения вероятности реализации ущерба в виде потери конфиденциальности активов, их целостности и доступности. Для реализации эффективной защиты могут предприниматься организационные и технические меры [64-66].

Организационные меры включают в себя разработку положений, регламентов и процессов взаимодействия. Эти меры должны приниматься в соответствии с законами и иными нормативно-правовыми актами в области ИБ.

Организационные меры не ограничиваются разработкой документов. Помимо них в организации реализуется: обучение или переобучение, выполнение всех

требований по защите данных, по обработке персональных данных (если исследуемую систему можно отнести к ИСПДН), организацию мероприятий по подготовке персонала для работы при возникновении экстренных ситуаций, получение лицензий на работу с государственной тайной или на деятельность в области защиты информации.

К техническим мерам обеспечения информационной безопасности можно отнести не только программные продукты (XSpider, SIEM, DLP-системы), но и иные инструменты, которыми обладает компания. Технические средства защиты должны опираться на модель информационной системы организации, которая может позволить построить эффективную защиту против кибератак. При построении такой ИС необходимо помнить несколько особенностей [67-69]:

а) структура архитектуры не должна быть перегружена, поэтому в системе должны присутствовать только те элементы, без которых она окажется нежизнеспособной;

б) при построении системы защиты, необходимо внедрять только сертифицированные средства защиты;

в) система должна администрироваться легко с минимальным использованием сторонней поддержки;

г) необходимо учитывать каждый возможный технический канал утечки информации, поскольку каждый из них должен иметь несколько рубежей системы защиты, которые могут затруднить работу потенциальному злоумышленнику;

д) необходимо фиксировать действия пользователей, чтобы по системному журналу при возникновении внештатной ситуации этот лог помог расследованию инцидента ИБ.

Помимо этих мер могут использоваться дополнительно средства криптографической защиты, обеспечивающих шифрование трафика, средства антивирусной защиты и иные системы, обеспечивающие закрытие потенциальных каналов утечки информации [67-69].

Влияние защитных мер на риск можно представить следующим образом (рисунок 8).

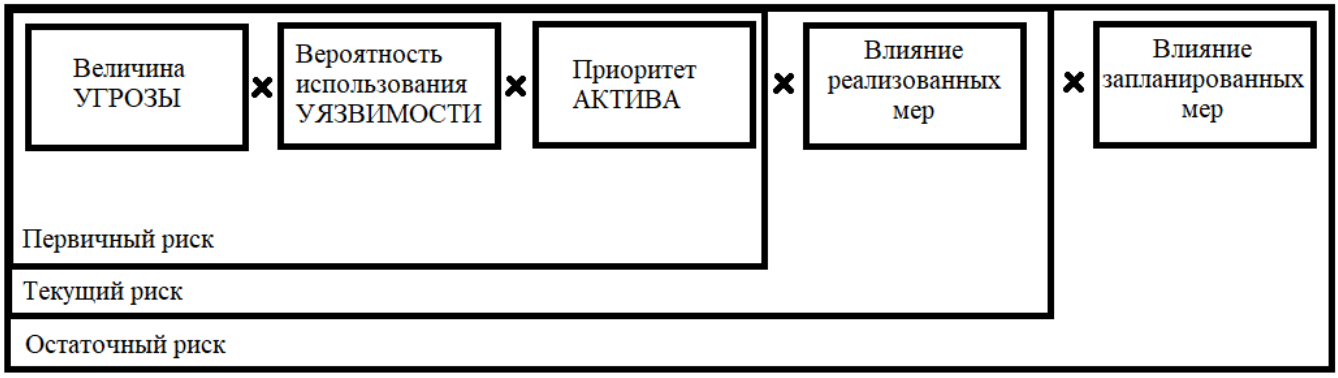


Рисунок 8 – Влияние защитных мер на риск

Снижение величины угрозы и/или вероятности может быть: низкое, среднее, высокое, полностью. Влияние реализованных мер показывает, насколько эффективно работают уже существующие механизмы защиты, а значение – реальный уровень риска в текущий момент времени. Влияние запланированных мер – снижение риска за счёт будущих защитных действий. Такая модель позволяет приоритизировать действия в рамках системы управления ИБ [67-69].

Грамотный выбор средств защиты позволяет предотвратить наступление инцидента, минимизировать его последствия. Однако выбор самих средств защиты осуществляется на основе разных стратегии управления рисками:

а) предупреждение или ликвидация: данная стратегия направлена на ликвидацию угрозы по средствам устранения источника угрозы – уязвимости в системе. Целью этой стратегии является полное исключение возможности наступления риска, не допуская реализации угроз;

б) снижение риска обеспечивается за счет повышения общего уровня защищенности, поскольку если принимаются дополнительные меры безопасности, то и сам нарушитель должен обладать более высоким потенциалом к нападению. Поэтому целью данной стратегии является уменьшение вероятности реализации угрозы и/или снижение ущерба при её реализации;

в) поглощение или принятие: если риск маловероятен, то организация может просто принять тот факт, что он может случиться и на случай его реализации

разрабатывает некую последовательность действий, позволяющих уменьшить последствия реализации риска. Цель – сознательное принятие риска, когда его уровень считается приемлемым или когда управление им экономически нецелесообразно;

г) компенсация ущерба: обеспечивается за счёт киберстрахования – современного способа защиты информационных рисков для организаций и предприятий. Страховка компенсирует ущерб, если другие средства цифровой безопасности окажутся неэффективными. Объектами страхования электронных рисков являются компьютерное оборудование, ценные бумаги, денежные средства, программное обеспечение, производственное оборудование, цифровые базы данных, объекты интеллектуальной собственности, иное имущества и права договоренности.

Программа страхования предусматривает возможность наступления следующих событий:

а) целенаправленная атака хакеров с целью контроля, дестабилизации, захвата информационной системы организации;

б) внедрение вирусов, вредоносного программного обеспечения, разработанного третьими лицами;

в) непредвиденные технические сбои, непреднамеренные ошибки, которые привели к негативным последствиям [62-69];

– реализация и проверка выбранных мер – процесс, включающий в себя непосредственное внедрение в эксплуатацию выбранных средств защиты информации и наладку их работы, их тестирование и испытанием системы в совокупности с реализованными мерами. По окончанию этих мероприятий осуществляется оценка соответствия систем защиты информации требованиям регуляторов в области информационной безопасности;

– оценка остаточного риска является ключевым этапом управления рисками, при котором определяется уровень риска, остающийся после внедрения всех запланированных мер защиты. Другими словами, имеется ситуация, при которой уровень текущего риска может быть ниже уровня остаточного риска. В таком случае дополнительных мер по снижению информационных рисков для указанного объекта

сети предпринимать не нужно. Это подчеркивает также тот факт, что полное устранение всех рисков часто просто не представляется возможным или практичным. При этом проблема современных подходов к оценке риска заключается в том, что большинство из них не рассматривают разделение механизмов защиты на типы, которое позволило бы более качественно проанализировать существующую систему защиты на предприятии [52-54].

Получаем классическую модель управления рисками в информационной безопасности, представленную на рисунке 9.

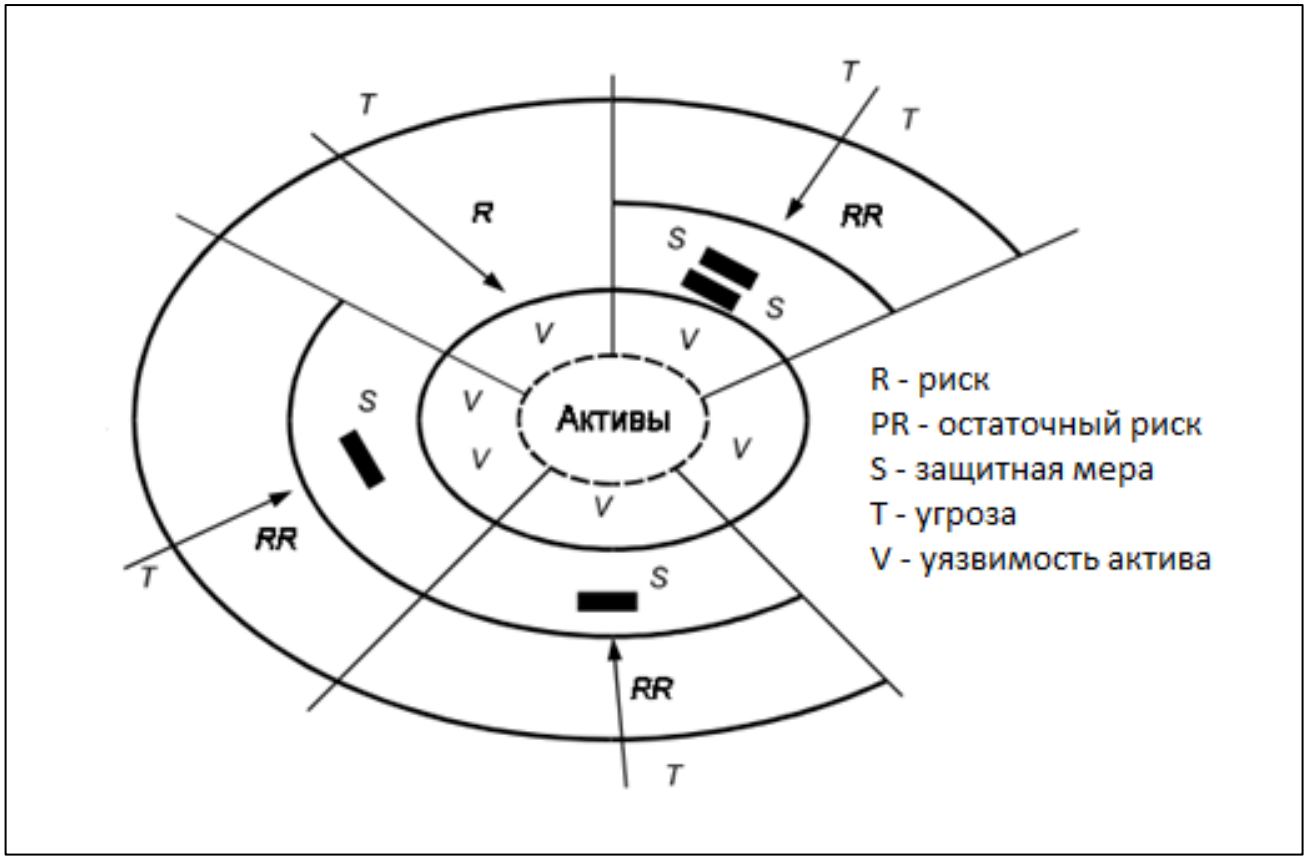


Рисунок 9 – Взаимосвязь компонентов безопасности

По данной схеме активы подвергаются угрозам через уязвимости, а защитные меры снижают риски, но не устраняют их полностью, поэтому остаются остаточные риски.

В результате анализа и систематизации информации были обобщены актуальные подходы и методы управления рисками, связанными с реализацией кибератак.

Наиболее эффективными являются многоуровневые модели управления рисками, сочетающие автоматизацию аналитики инцидентов и гибкое принятие решений на основе остаточного риска. Кроме того, усиливается роль прогностических методов и ИИ-систем в оценке и снижении рисков кибератак.

Таким образом, полученные результаты позволят сформировать обоснованную методическую базу для дальнейшего построения системы управления рисками информационной безопасности с учетом современных угроз и практик.

2 Применение дискретных распределений для оценки и регулирования рисками

2.1 Анализ дискретных распределений для задач управления рисками в ИБ

2.1.1 Биномиальное распределение

Риск – произведение величины ущерба на вероятность его наступления. Данная функция является стохастической, поскольку его составляющие, такие как нанесенный атакой ущерб, вероятность успешности реализации атаки, набор реализованных угроз, являются неопределенными и случайными параметрами. В связи с этим свойством риска целесообразно использовать вероятностные инструменты – дискретные распределения, такие как биноминальное распределение, мультиномиальное распределение, гипергеометрическое распределение, геометрическое распределение, распределение Пуассона, распределение Паскаля [70-72].

Дискретные распределения позволяют формально описать случайные события, которые происходят с определенной вероятностью. Их целесообразно использовать ввиду не детерминированности современных кибератак, поскольку они зависят от большого количества факторов и могут иметь разные последствия. Благодаря данным распределениям можно описывать последствия как единичных, так и множественных атак. Помимо этого, в сфере ИБ основные рассматриваемые элементы – это целочисленные, конечные величины, характеризующиеся ограниченным набором данных. Дискретные распределения позволяют более точно оценить вероятности конкретных исходов, что важно для построения огибающих функций управления, выделения критичных диапазонов [70-72].

Рассмотрим способы использования дискретных распределений при управлении рисками успешности реализации кибератак:

Биномиальное распределение – одно из наиболее распространённых дискретных распределений, которое применяется для определения вероятности появления некоторых событий x раз в n независимых испытания, когда вероятность события p в каждом из испытаний постоянна. Данное распределение определяется формулой 1 [70]:

$$f(x;n,p) = C_n^x p^x (1-p)^{n-x}, x = 0,1,2,.n \quad (1)$$

Биномиальное распределение может моделировать количество успешно совершенных атак k за n количество попыток с некоторой вероятностью успеха, которая является равновероятной величиной независимо от самих атак. Отсюда данное распределение может использоваться для исследования таких атак, как фишинг (за n количество писем имеем одинаковую вероятность открытия писем у конечного пользователя), bruteforce (вероятность успешного подбора пароля за n количество попыток) или же реализации конкретной CVE в рамках некоторого шаблона атак [73-74].

Такие статистические параметры биномиального распределения, как математическое ожидание, дисперсия рассчитываются по формулам 2 и 3:

$$M(X) = np \quad (2)$$

$$D(X) = np(1-p) \quad (3)$$

Математическое ожидание отражает среднее значение дискретной случайной величины и позволяет сделать прогноз, какое значение данная величина может принять далее. При управлении рисками математическое ожидание является важным параметром, поскольку позволяет сравнить различные сценарии атак при разных параметрах, понять необходимо ли внедрять дополнительные меры защиты с целью снизить риск или увидеть, что эти же дополнительные меры будут бесполезны ввиду того, что уровень текущего риска меньше уровня остаточного риска [75].

Дисперсия отражает разброс между результатами и при небольших значениях позволяет увидеть есть ли риск возникновения критического ущерба, при нанесении которого могут быть серьёзные последствия. Однако в противном случае специалистам необходимо разработать дополнительные меры защиты, которые могут помочь снизить риск возникновения ущерба, критического для информационной системы [76].

Огибающая распределения будет видоизменяться при изменении вероятности p, смещаясь вправо, если p растет или смещаясь влево, если p уменьшается.

2.1.2 Мультиномиальное распределение

Мультиномиальное распределение является обобщением биномиального распределения двух и более случайных величин (актуально для случаев, когда возможны более двух исходов), если имеем некоторые зависимые испытания случайного эксперимента с несколькими возможными исходами [6]. Данное распределение используется для определения вероятности появления i события x раз при количестве испытаний n, когда вероятности событий p постоянны и сами события образуют полную группу. Иными словами, данное распределение имеет широкое применение в случае, когда одно событие (кибератака) может закончиться разными результатами с разными вероятностями. Мультиномиальное распределение определяется формулой 4 [70, 77]:

$$f(x_1, \dots x_k : n; p_1, \dots p_k) = \frac{n!}{x_1! \dots x_k!} p_1^{x1} \dots p_1^{xk}, x_i = 0,1,2, \dots (i = 1, \dots, k); \quad (4)$$

$$x_1 + x_2 + \dots + x_k = n$$

Особенностями данного распределения являются наличие нескольких возможных исходов, поскольку оно учитывает результаты разного рода одного эксперимента в отличие от биномиального распределения (где имеем только два исхода – успех/неудача). Сами же вероятности, при отсутствии воздействия внешних факторов остаются постоянными (специалист по ИБ может задуматься о распределении ресурсов между объектами защиты для повышения их степени защищенности). Количество испытаний также остается фиксированным, в отличие от распределения Пуассона, где число событий может быть неограниченным. Отсюда получаем, что мультиномиальное распределение полезно при изучении кибератак,

которые могут приводить к разным последствиям будь то тот же самый фишинг, реализация которого может привести к краже конфиденциальной информации (p_1), установке ВПО (p_2), обман сотрудника с целью получить денежные средства (p_3), неудачная реализация атаки, или же DDos-атака, результатами которого могут быть или временное замедление сервиса (p_1), или полный отказ в обслуживании ИС (p_2), или блокировка попыток этой атаки. Помимо этих способов применения мультиномиальное распределение может использоваться в случае, если множественная атака эксплуатирует несколько уязвимостей, и нужно оценить вероятность успешного доступа к каждому из них [77].

Такие статистические параметры мультиномиального распределения, как математическое ожидание, дисперсия рассчитываются по формулам 5 и 6:

$$M(X) = np_i \tag{5}$$

$$D(X) = np_i(1 - p_i), i = 1,2,..,k \tag{6}$$

Поскольку имеется несколько разных исходов соответственно расчёт математического ожидания для разных вероятностей позволит получить разные результаты для изучения и оценки. Изучение тех или иных последствий кибератак позволит принять решение о дальнейшем распределении имеющихся ресурсов, поскольку, если вероятность наступления крайне негативного события или возможных более серьезных атак очень высока, то специалистам необходимо будет принять дополнительные меры, чтобы снизить эту вероятность и, соответственно, снизить риск. Дисперсия же позволит увидеть, насколько предсказуемыми будут последующие события. При высоких значениях специалистам не только надо быть готовыми к худшему сценарию ввиду его непредсказуемости, но и предусмотреть аварийные меры защиты.

2.1.3 Гипергеометрическое распределение

Гипергеометрическое распределение – используется для моделирования числа удачных выборок без возвращения из конечной совокупности, при этом вероятность успеха меняется после каждого испытания. Это универсальный математический инструмент, широко используемый при решении задач, связанных с контролем качества продукции. Данное распределение определяет вероятность появления x исправных изделий в выборке объема m, взятой из совокупности объема n, которая содержит k неисправных изделий. Гипергеометрическое распределение определяется формулой 7 [70, 78, 79]:

$$f(x;n,k,m)=\frac{C_k^x C_{n-k}^{m-x}}{C_n^m};x\le k;m-x\le n-k; \quad (7)$$

Особенности данного распределения заключаются в том, что каждая новая попытка зависит от предыдущих. Так, если злоумышленник смог удачно скомпрометировать целевую систему, то вероятность следующего взлома изменяется, при этом гипергеометрическое распределение дает более точные прогнозы, по сравнению с биномиальным, поскольку рассматриваемая выборка больше не используется и для продолжения анализа необходимо работать с новой выборкой.

Отсюда, ввиду конечности среды можно понять, что гипергеометрическое распределение может использоваться для изучения, анализа кибератак при конечной атакуемой среде (к этой среде можно отнести отдельных пользователей, файлы, иные системы). Для регулирования риска целесообразно пытаться уменьшить число элементов с некоторым свойством (k), но при этом не забывать, что генеральная совокупность (n) также может уменьшаться [70, 78, 79].

Такие статистические параметры гипергеометрического распределения, как математическое ожидание, дисперсия рассчитываются по формулам 8 и 9, а

огибающая распределения при параметрах k=10, m=15, n=50 представлен на рисунке 10:

$$M(X) = \frac{nk}{m} \quad (8)$$

$$D(X) = \frac{nk(m-k)(m-n)}{m^2(m-1)} \quad (9)$$

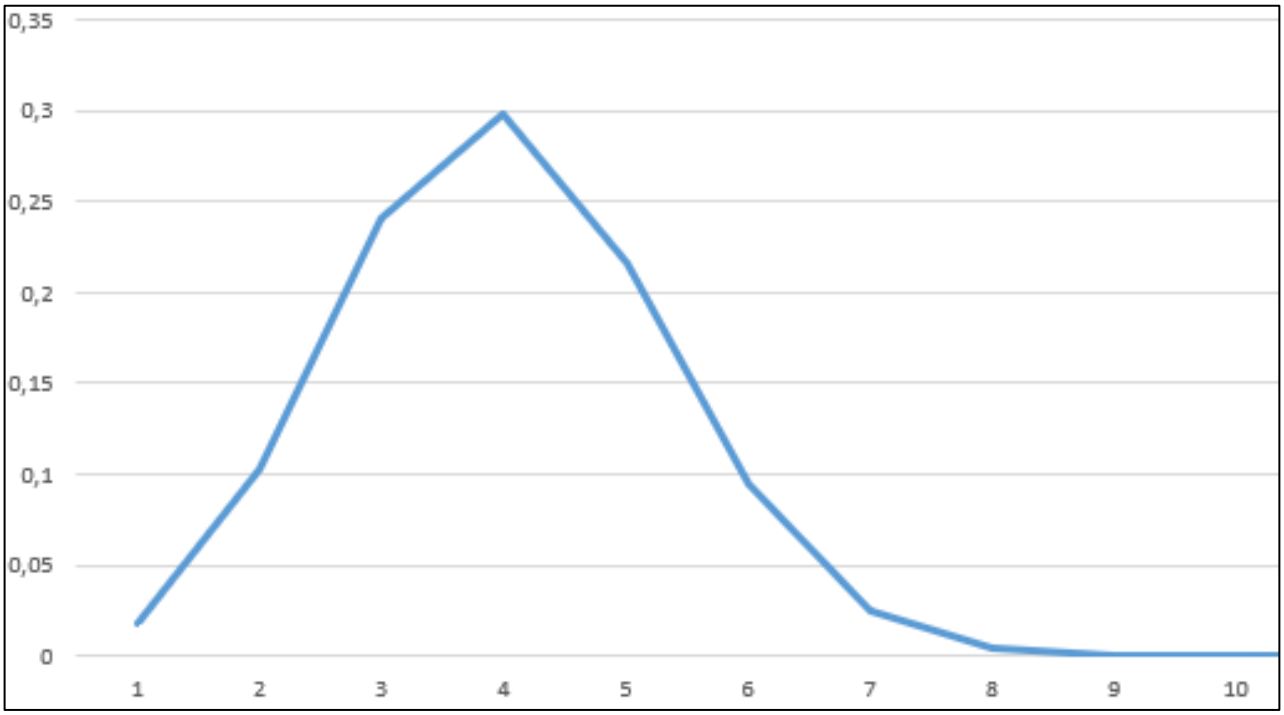


Рисунок 10 – Гипергеометрическое распределение

2.1.4 Геометрическое распределение

Геометрическое распределение, так же, как и биномиальное, представляет собой семейство распределений, но с одним параметром p, который равен вероятности успеха в одном испытании Бернули [9]. Данное распределение применяется, чтобы определить вероятность того, что потребуется x испытаний Бернули, прежде чем будет получен успешный исход. Геометрическое распределение определяется формулой 10 [70, 80]:

$$f(x; p) = p(1-p)^x; x = 1,2.. \quad (10)$$

При данном распределении вероятность успеха в следующий попытке не зависит от предыдущих результатов, более того, она падает с увеличением числа попыток, отсюда атаки с большей вероятностью успеха (p) имеют более высокие шансы пройти с первых попыток.

Геометрическое распределение позволяет понять степень уязвимости рассматриваемой информационной системы, поскольку большинство атак могут быть или успешно реализованы сразу, или спустя несколько попыток. Однако во втором случае вероятность каждой последующей будет уменьшаться, что может сказаться на успешности реализации самой атаки.

Такие статистические параметры геометрического распределения, как математическое ожидание, дисперсия рассчитываются по формулам 11 и 12, огибающая этого распределения представлена на рисунке 11 [70, 80]:

$$M(X) = \frac{1-p}{p} \tag{11}$$

$$D(X) = \frac{1-p}{p^2} \tag{12}$$

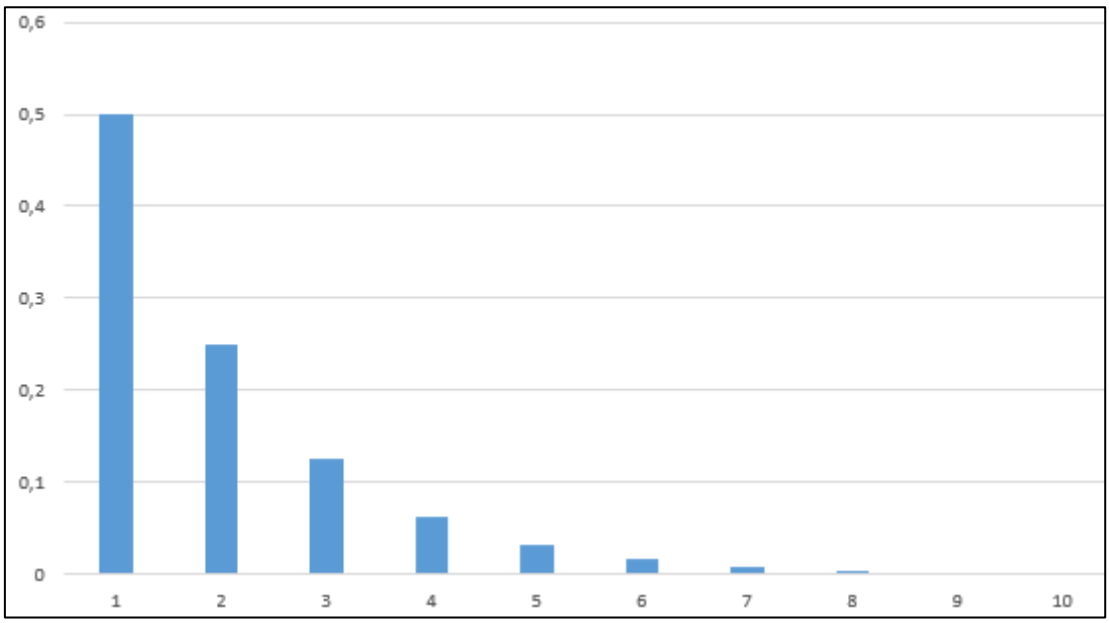


Рисунок 11 – Геометрическое распределение

Графическое отображение также подтверждает факты, перечисленные выше.

2.1.5 Распределение Паскаля

Распределение Паскаля (или отрицательное биномиальное) определяет вероятность того, что потребуется провести x испытаний Бернули для появления s успешных исходов. Иными словами, данное распределение позволяет смоделировать некое число попыток до достижения успеха, по сравнению с геометрическим, учитывающим только первый успех. Распределение Паскаля определяется формулой 13 [70, 81, 82]:

$$f(x; s, p) = C_{x+s-1}^{s-1} p^s (1-p)^x, x = 0,1,2,\ldots \quad (13)$$

Данное распределение не ограничено как биномиальное, а наоборот, может увеличиваться при росте числа попыток, поскольку результат может быть не достигнут за заданное количество. Поэтому при переборе пароля, фишинге, попытки будут продолжаться пока не будет положительного результата. При этом данное распределение может использоваться для оценки интенсивности атак, моделирования всплесков активности злоумышленников, прогнозирования частоты появления уязвимостей.

Такие статистические параметры распределения Паскаля, как математическое ожидание, дисперсия рассчитываются по формулам 14 и 15:

$$M(X) = \frac{s(1-p)}{p}; \quad (14)$$

$$D(X) = \frac{s(1-p)}{p^2}. \quad (15)$$

2.1.6 Распределение Пуассона

Распределение Пуассона является частным случаем биномиального распределения. Оно определяет вероятность появления x независимых событий в данном интервале времени t, когда события происходят с постоянной интенсивностью λ. Получаем, что данное распределение используется для оценки вероятности редких событий за фиксированный промежуток времени. Распределение Пуассона определяется формулой 16 [70, 83]:

$$f(x;\lambda) = \frac{(\lambda t)^x}{x!} e^{-\lambda t}, x = 0,1,2,\ldots \quad (16)$$

Распределение Пуассона возникает в теории потоков событий. Формула 16 применима при атаках на некоторый объект, когда число атак велико, а число удачных попыток проникновения мало, тогда закон распределения случайной величины «ущерб от удачной атаки» имеет вид распределения Пуассона. Более того, данное распределение можно использовать для прогнозирования числа редких кибератак за некоторый фиксированный период, при этом сами атаки происходят независимо друг от друга. Помимо этого, его можно использовать для моделирования устойчивости системы, оценки вероятности достижения критического состояния, моделирования успешности атак при неоднородной защищенности сегментов. Такие статистические параметры распределения Паскаля, как математическое ожидание, дисперсия рассчитываются по формулам 17 и 18:

$$M(X) = \lambda t \quad (17)$$

$$D(X) = \lambda t \quad (18)$$

Получаем, что целесообразность использования каждого из рассматриваемых дискретных распределений определяется особенностями проектной ситуации, в рамках которой производится оценка и регулирование рисками.

2.2 Выбор дискретного распределения

Каждое распределение характеризуется собственными предпосылками, структурой входных параметров и типом моделируемого случайного процесса, что позволяет обоснованно соотносить его применение с конкретными условиями и характеристиками исследуемой ИБ-среды [84].

Выбор распределения будет зависеть от:

– типа процесса, подразумевающего один процесс или несколько категорий исходов;

– характера событий – независимые/зависимые, с постоянной/меняющейся вероятностью;

– дисперсионных характеристик – равенство или неравенство среднего и дисперсии. В данной ситуации сравнение дисперсии и математического ожидания позволит определить характер случайного процесса, тип стохастической зависимости между событиями, адекватность модели для описания данных. Более того, это сравнение является быстрым диагностическим инструментом, который позволяет отсеять неподходящие модели, выявить скрытые паттерны, снизить ошибки прогнозирования на 15-30% [54].

Выбор распределения должен отражать не только статистические свойства данных, но и природу моделируемых угроз. В ИБ нет идеальных моделей, но правильный выбор распределения сокращает «слепые зоны в оценке рисков». Графически выбор дискретного распределения представлен на рисунке 12.

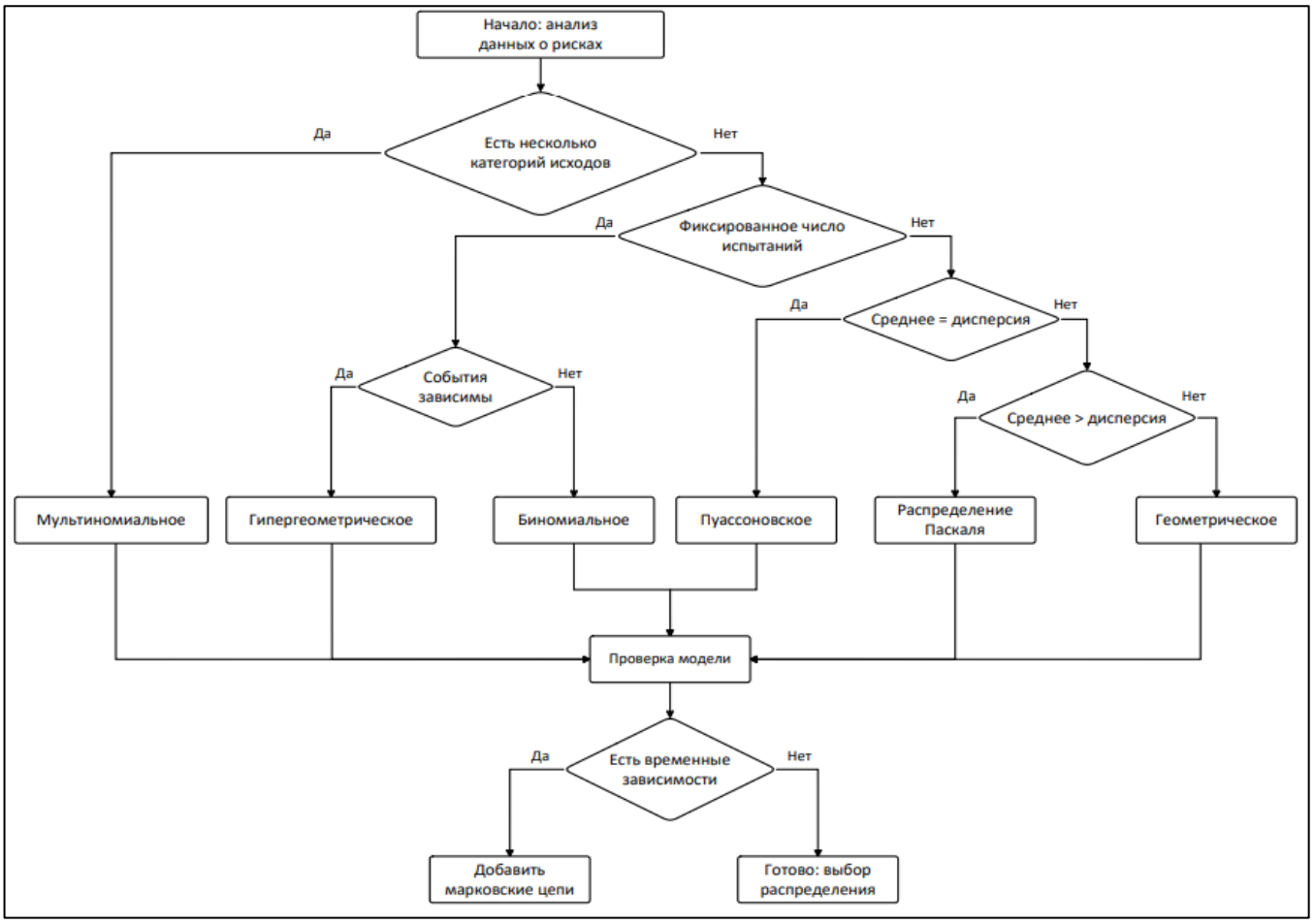


Рисунок 12 – Выбор дискретного распределения

В результате анализа дискретных распределений были определены ситуации, в которых эти распределения могут быть использованы, разработана методика выбора дискретных распределений для оценки и управления рисками информационной безопасности.

Среди всех дискретных распределений рассмотрим биномиальное и гипергеометрическое, как наиболее управляемые, интерпретируемые и применимые к проектным ситуациям.

3 Разработка методик регулирования рисков с использованием выбранных распределений

3.1 Регулирование риска с использованием биномиального распределения

3.1.1 Обоснование выбора биномиального распределения и выбор регулируемого параметра

Инвариант суммы рисков, равный математическому ожиданию ущерба, означает, что при любых перестановках вероятностей и значений ущерба суммарный ожидаемый риск остается прежним и равным 1.

При защите одного актива, осуществляя попытки снижения вероятности атаки на него, нарушитель может переключить своё внимание на другой актив, являющийся менее защищенным. Укрепляя одни зоны тем самым прикладывая усилия по снижению риска в одних диапазонах величин ущерба, происходит рост этого уровня в других диапазонах.

Биномиальное распределение используется для описания атак, реализация которых имеет два исхода (успех/неудача). Также их можно рассматривать, как серия одинаковых атак через 1 единственную уязвимость [85-89].

Расчет вероятности наступления ущерба осуществляется через формулу 19:

$$P(x, n, p) = C_n^x p^x (1-p)^{n-x}, \text{ x} = 0,1,2\ldots\text{n} \quad (19)$$

где x – число успехов;

n – количество совершенных атак;

p – вероятность успешности реализации атаки.

Число успехов – случайная величина, которая определяет сколько раз произошло событие «успех» в серии из n независимых испытаний. При обеспечении кибербезопасности данный параметр определяет число успехов при совершении атак в количестве n.

Количество совершенных атак n является фиксированной величиной, которая зависит исключительно от злоумышленника. Данный факт можно подтвердить тем,

что только он сам решает: атаковать ему или нет, если атаковать, то, когда и сколько раз, после чего уже на какой целевой объект будет направлена сама атака и с какой интенсивностью. Помимо этого, при построении модели риска мы моделируем гипотетическое поведение злоумышленника, что важно именно для сценарного риска и определения устойчивости системы. Таким образом ввиду того, что число успехов является случайной величиной, а количество совершенных атак – параметр, зависящий от злоумышленника, можно сделать вывод, что на данные параметры специалист по ИБ повлиять не может [85-89].

Тогда биномиальное распределение изучаемой ситуации (при n=10, p=0,5) имеет вид, представленный на рисунке 13.

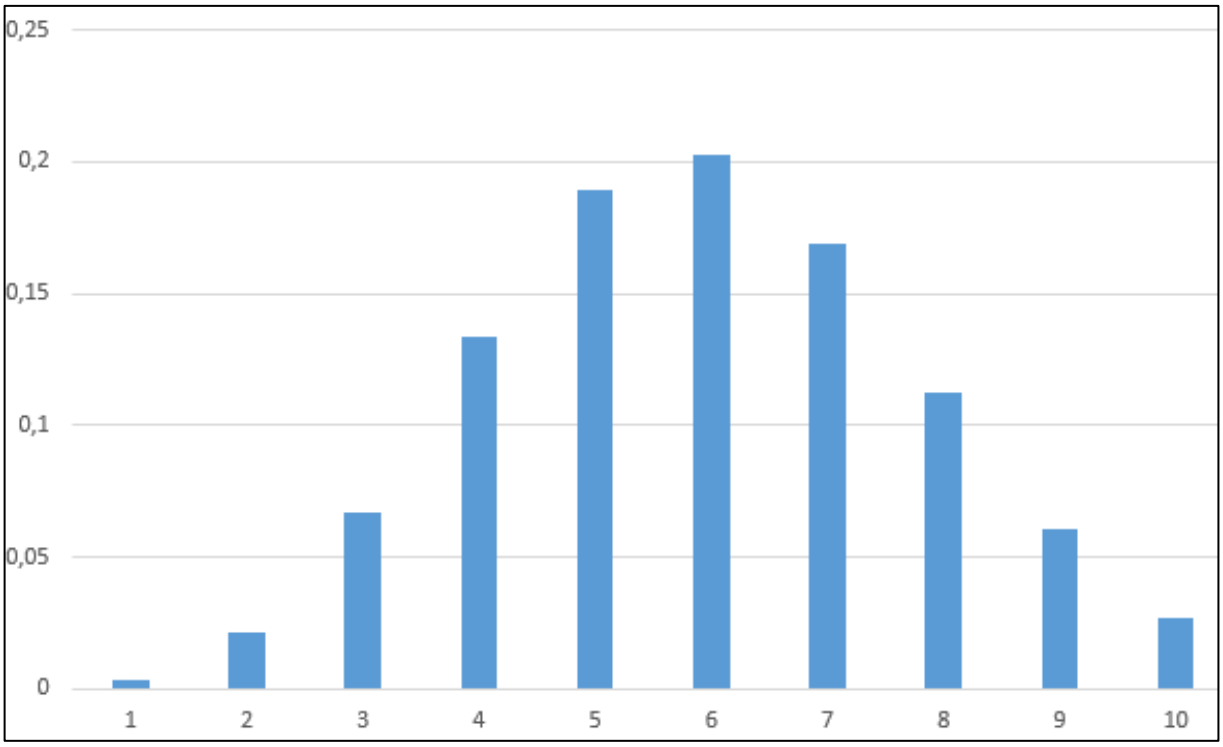


Рисунок 13 – Биномиальное распределение при n=10, p=0,5

При этом распределение будет смещаться в правую или левую сторону в зависимости от изменения параметра p. При снижении этого параметра до 0,01 имеем следующее распределение, представленное на рисунке 14.

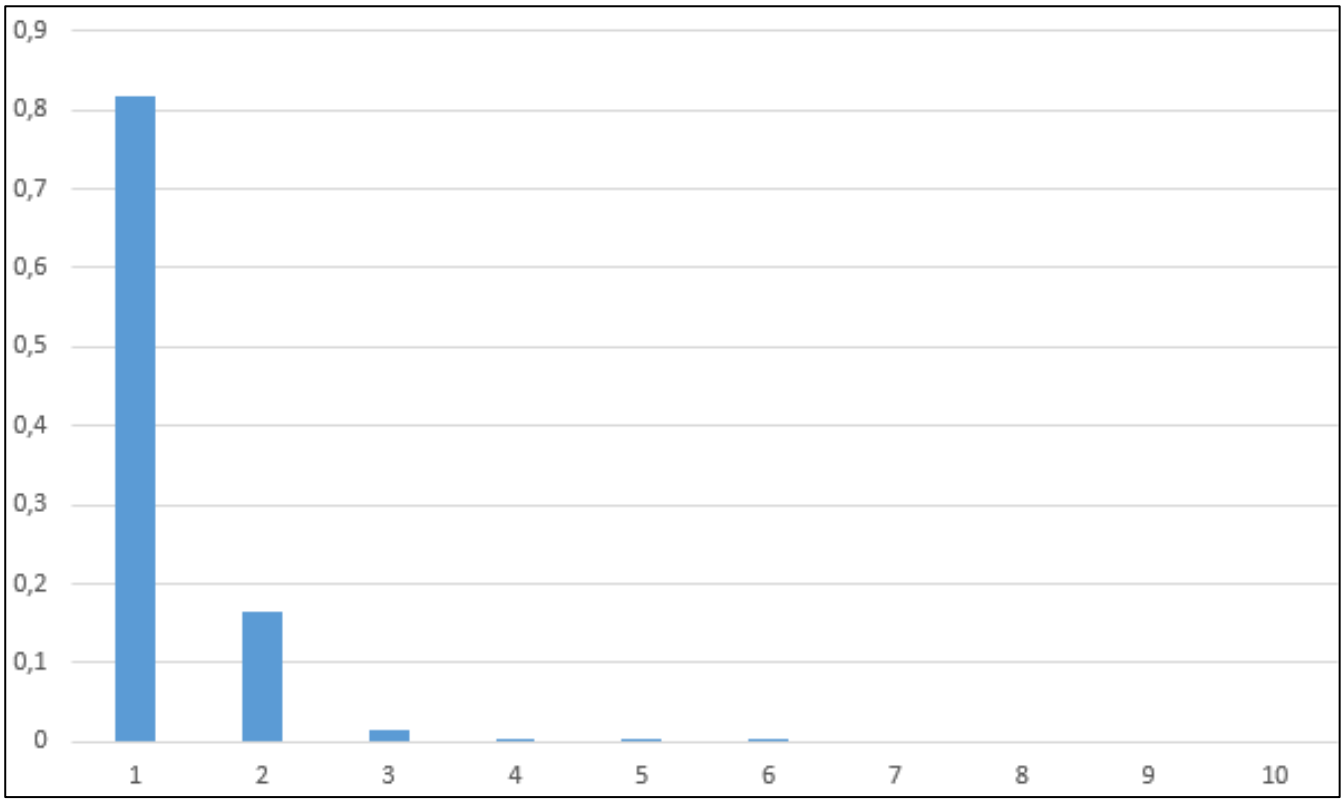


Рисунок 14 – Биномиальное распределение при p=0,01

В противном же случае, при повышении этого параметра до практически самого максимального значения – 0,99, получим распределение, представленное на рисунке 15.

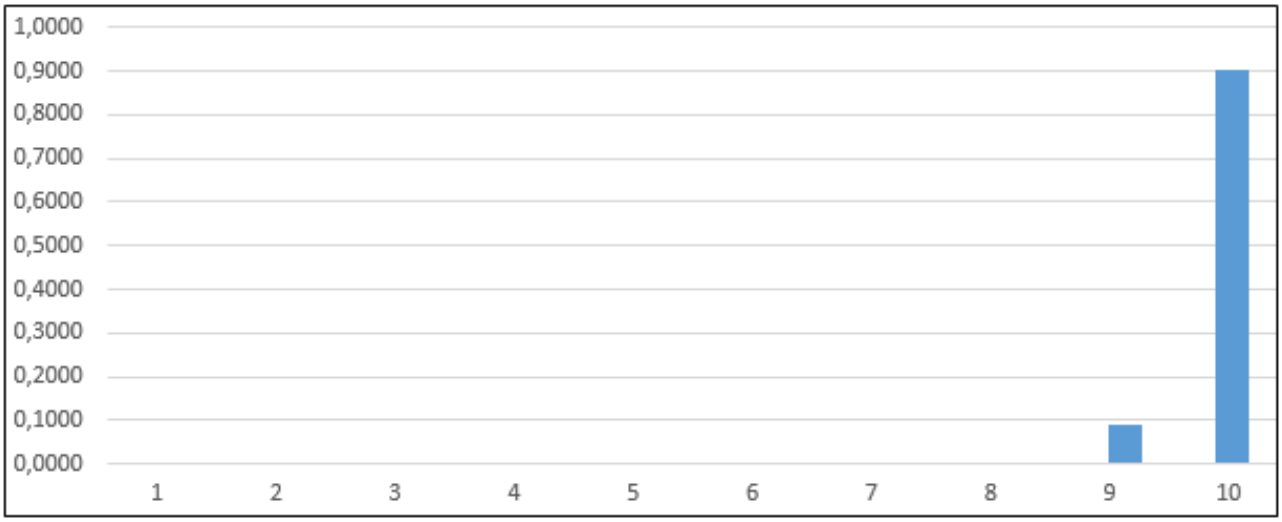


Рисунок 15 – Биномиальное распределение при p=0,99

Определение вероятности $p_{кр}$, при которой риск в заданном диапазоне ущерба не превышает заданного уровня, позволит определить уровень, до которого нужно будет снизить исходную вероятность. Если атака направлена на нарушение работы оборудования, кражи данных, НСД, то само снижение вероятности осуществляется за счёт внедрение тех или иных средств защиты информации или организационно-правовых мер. Если же атака носит социальный характер (фишинг), то есть направлена на человека, на побуждение его к каким-то действиям, то необходимо использовать организационно-правовые меры, направленные на повышение осведомленности сотрудников и понижения соответствующей вероятности.

В рамках анализа фишинга целесообразно рассматривать последний предложенный метод, как метод регулирования рисков, поскольку это является одним из наиболее эффективных способов борьбы с ним. При этом на это влияет само качество обучения, периодичность закрепления старого материала и своевременное изучение нового, а начальная вероятность успешности атаки не будет равняться 0,5, а будет определяться ростом числа обученных сотрудников [90-91].

Приведем немного статистики (IBM, KnowBe4, tadviser): 60% сотрудников способны открыть вредоносную ссылку, вложение, архив с ВПО, exe-файл или иное фишинговое сообщение, поскольку не смогли правильно идентифицировать эти письма, при этом 30% могут передать учетные данные. Более того, необходимо учитывать, что не каждый переход по ссылке приводит к компрометации, поэтому учитывается последовательность всех действия, начиная от нажатия, ввода данных. Поэтому получаем, что успешность фишинг-атаки на необученного сотрудника 2,5%-5%, тогда как на обученного 0,5%-1,5%. Отсюда получаем средние значения последней статистики равные 3,5% и 1% соответственно. Тогда, исходя из полученной статистики, вероятность успешности атаки на необученных сотрудников будет равна $p_u = 0{,}035$, а на обученных $p_t = 0{,}01$. Отсюда получим приблизительное значение, во сколько раз вероятность атаки на обученного сотрудника больше, чем на необученного (формула 20):

$$R = \frac{p_u}{p_t} = \frac{0{,}035}{0{,}01} = 3{,}5 \quad (20)$$

Получаем, что вероятность того, что вероятность успешности атаки на необученных сотрудников больше, чем на необученного в 3,5 раза.

Составим новую форму расчета вероятности, исходя из конкретной задачи – защиты от фишинга.

Введем переменные, пусть:

N – общее число сотрудников;

x_t – количество обученных сотрудников;

p_u – вероятность успеха на необученного сотрудника;

p_t – вероятность успеха на обученного сотрудника.

Сама вероятность успеха атаки на необученного сотрудника составляет 0,5, поскольку они может как сделать интересующее злоумышленника действие, так и нет [90-91].

Тогда новая вероятность, учитывающая эти параметры будет рассчитываться следующим образом по формуле 21:

$$p_y = \frac{(N - x_t)p_u + x_t p_t}{N} \quad (21)$$

Отсюда достигая значения вероятности путем обучения сотрудников, мы можем достичь значения риска ниже заданного уровня в указанном диапазоне.

Проведенный анализ позволяет сделать вывод, что вероятность успешности реализации атаки – параметр, на который может повлиять специалист ИБ, при этом данный расчет является альтернативой расчета риска при конкретном типе атаки.

3.1.2 Методика регулирования риска с использованием биномиального распределения

При расчете риска также необходимо учитывать уязвимость, через которую будет реализована угроза. Для анализа уязвимостей используются различные метрики. Однако в контексте обеспечения информационной безопасности целесообразно рассматривать несколько механизмов документирования и оценки, позволяющих получить среднюю оценку на их основе. Таковыми инструментами являются калькуляторы CVSS, EPSS, OWASP, поскольку в отличие от иных аналогов они не являются узконаправленными. Более того они имеют понятный и удобный для пользователя интерфейс, позволяющий осуществить расчет необходимой оценки [93-96].

Исходными данными для получения финальной оценки являются оценки критичности из калькуляторов CVSS 3.1, CVSS 4.0, EPSS, OWASP. Результаты работы этих калькуляторов основаны на группе метрик, которые остаются неизменными с течением времени.

Дальше необходимо произвести ряд следующих действий [37]:

– нормализация оценок по формуле 22:

$$s_{norm} = \frac{s - s_{min}}{s_{max} - s_{min}} \quad (22)$$

где s_{norm} – нормализованная оценка;

s_{min} – минимальная оценка в калькуляторе;

s_{max} – минимальная оценка в калькуляторе.

– расчет среднеквадратичной оценки по формуле 23:

$$s_{final} = \sqrt{\frac{1}{n}\sum_{i=1}^{n} s_{norm.i}^2} \quad (23)$$

где S_{final} – среднеквадратическая оценка.

Таким образом, мы получаем среднеквадратичную оценку. Её целесообразно рассматривать, поскольку данный метод учитывает вариативность самих данных и влияние крайних значений.

При использовании биномиального распределения рассматривается ситуация использования серии одинаковых кибератак через одну уязвимость, но сценарии осуществления могут варьироваться в зависимости от используемой уязвимости среди возможного перечня уязвимостей, поскольку пары «вид атаки – эксплуатируемая уязвимость» формируются следующим образом:

– на основе классификации CAPEC или MITRE идентифицируем i-й вид атаки;

– на основе базы CAPEC и классификации CWE определяются ошибки, которые могут быть эксплуатированы i-м видом атаки;

– на основе базы CVE определяем уязвимости, которые соответствуют программным ошибкам;

– с помощью ресурса CISA CEV производим выборку наиболее актуальных уязвимостей;

– определение уязвимостей, характерных, для защищаемой системы, объекта, актива [93-96].

Имеем, что одной программной ошибке может соответствовать несколько уязвимостей. На основе суммы среднеквадратических оценок и среднеквадратической оценки конкретной эксплуатируемой уязвимости получаем вероятность эксплуатации единичной уязвимости p_{cve} (формула 24):

$$p_{cve} = \frac{s_{final}}{\sum_{i=1}^{M} s_{final}} \tag{24}$$

При расчете риска успешности реализации кибератаки целесообразно рассматривать связки: CAPEC-CWE-CVE. Это позволит оценить, насколько реалистично, что шаблон CAPEC будет использован в конкретной системе с успешным результатом.

Использование базы CAPEC для оценки риска атак позволяет перейти от оценки отдельных уязвимостей, связок CWE-CVE, к анализу шаблонов атак, отражающих поведение атакующего. База данных CAPEC позволяет обеспечить уровень обобщения, необходимый для стратегического управления рисками. Она ориентирована на тактико-технические сценарии и позволяет оценивать не только наличие уязвимости, но и вероятность её практической реализации.

Переход от шаблона атаки CAPEC к категории уязвимостей CWE позволяет связать обобщенные сценарии атак с конкретными техническими слабыми местами, которые могут быть реализованы в инфраструктуре. При рассмотрении конкретного CWE становится рассматривать связанные с ним CVE.

Для оценки вероятности успешной реализации шаблона CAPEC можно использовать среднее значение EPSS для всех связанных с CWE CVE. Оценка EPSS – это вероятность того, что уязвимость действительно будет эксплуатироваться в реальности. Она дает динамическую оценку на основе реальных данных об объективности атак и подчеркивает факт эксплуатации. Её целесообразно использовать ввиду того, что оценка CVSS v3.1, CVSS v4.0 позволяет оценивать ущерб и технические характеристики, а оценка OWASP зависит от человека и контекста и является субъективной экспертной оценкой. Отсюда получаем, что оценка EPSS – объективный индикатор «живости» шаблона атаки [93].

Тогда для оценки вероятности успешной реализации шаблона CAPEC можно использовать следующую формулу 25:

$$p_{capec} = \frac{1}{M}\sum_{i=1}^{M} EPSS(CVEi) \quad (25)$$

где M – количество CVE, связанных с шаблоном CAPEC через конкретный CWE;

EPSS(CVEi) – значение EPSS для каждой уязвимости.

Ни на p_{capec}, ни на p_{cve} специалист по ИБ повлиять не может, поскольку эти вероятности получается на основе статистических данных.

Отсюда получаем, что единственный параметр, на который может повлиять специалист по ИБ является вероятность успешности реализации атаки за счет внедрения тех или иных технических, организационно-правовых, криптографических и физических мер защиты информации.

Обозначим целевую меру эффективности защиты информации, как E_k. Этот параметр может задаваться экспертно или по данным. Каждая мера защиты информации будет определяет максимальное влияние на снижение исходной вероятности, поэтому необходимо ввести вариант оценки значения этого параметра, что представлено в таблице 1.

Таблица 1 – Вариант оценки значения мер защиты информации

Качественная оценка параметров	Количественная оценка параметров
Меры умеренной эффективности	0,3
Меры средней эффективности	0,5
Высокоэффективные меры	0,9

Применение меры умеренной эффективности обеспечит заметное, но недостаточное снижение риска, что означает, что мера помогает, но не решает проблему полностью. Такими мерами являются базовое обучение, фильтры почты, двухфакторная аутентификация и другие.

Применение меры средней эффективности позволяет сказать о том, что принятая мера дает серьезную защиту, заметно снижает риск, но проблему полностью не решает. Таковыми мерами являются стандартные правила Firewall, блокирующие половину попыток, DLP-системы базового уровня и другие [60].

Высокоэффективные меры почти полностью нейтрализуют конкретный вектор атаки, но риск всегда остается. Особенностью таких мер можно считать использование современных технологий, лучших тактик противоборства, регулярных тестирований и аудитов. Мерами позволяющими с высокой эффективностью снизить риск являются: использование EDR/XDR-систем, многоступенчатых систем защиты с обучением, непрерывных тестов от Red Team/Purple Team.

Таким образом, вероятность с учетом внедренных мер защиты информации получаем следующую формулу получения вероятности успешности реализации атаки (формула 26):

$$p_{\text{у}} = p_{\text{исх}} * \prod_{i=1}^{K}(1 - E_i) \quad (26)$$

где $p_{\text{исх}}$ – исходная вероятность.

K – количество введенных мер.

Мы используем в формуле (1-Ei), чтобы получить долю вероятности, которая остается после применения меры, то есть остаточный риск.

Может быть и обратная ситуация, когда нам необходимо повысить вероятность и увеличить риск при больших значениях ущерба. Это может использоваться в качестве управляемого эксперимента для моделирования наихудшего сценария, обоснования необходимости инвестирования средств в защиту. Поэтому активное повышение вероятности успешной реализации атаки целесообразно применять в целях пентестинга, Red Team-операций и оценки защищенности. Искусственное повышение вероятности достигается за счет снижения эффективности мер защиты или полное их отсутствие. В результате чего можем иметь следующую ситуацию (формула 27):

$$p_{\text{у}} = p_{\text{исх}} \quad (27)$$

Таким образом целесообразно ввести величину, включающую в себя все 3 вероятности (формула 28):

$$F_j\left(p_{\text{у}}, p_{cve}, p_{capec}\right) = p_{\text{у}} * p_{cve} * p_{capec} \quad (28)$$

Для оценки влияния защитных мер на итоговую вероятность успешности реализации атаки можно использовать градиентный подход, что позволит

определить, какие меры оказывают наибольшее влияние на риск, количественно оценить их эффективность и принимать решения о приоритетах при выборе защитных стратегий.

Исходя из этого, становится целесообразным использование принципа обратной связи. Задача представляет собой стохастическую схему, где возмущение по «Основам теории управления» – атака с заданной вероятностью успеха. Управляющим воздействием u_t, изменяемым на основе текущего состояния системы является средство управления. Модель возмущений – сам случайный процесс. Его целесообразно использовать, поскольку принцип обратной связи предполагает постоянное обновление u_t на основе текущей ошибки управления [97].

Система мониторинга считает уровень риска и определяет до какого уровня необходимо понизить вероятность, чтобы в заданном диапазоне ущерба уровень риска не превышал допустимого уровня. Алгоритм управления усиливает меры, внедряя их в систему.

Управляющим воздействием является вектор $u_j = \{u_{1,t},u_{2,t},\ldots..u_{k,t}\}$, где $u_{j,t} \in [0,E_j]$, $j = 1\ldots.K$, который будет влиять на вероятность. При этом сами меры носят временный характер, теряя свою эффективность, устаревая, с каждым некоторым шагом. В рамках регулирования рисков и определения наиболее подходящего варианта параметров целесообразно регулировать эти параметры, чтобы увидеть, как меняется вероятность. Выбор мер основывается на их эффективности и имеющемся бюджете на их реализацию, поскольку цена на разрабатываемые средства растет, как и спрос на более современное оборудование. Имея неограниченный бюджет, защита организаций достигла бы беспрецедентного уровня, однако абсолютной безопасности даже в этом случае существовать не может. Организация может получить идеальную инфраструктурную безопасность, сверхсовременные технологии, человеческий фактор под контролем благодаря постоянному обучению, своевременному отсеву сотрудников с высоким риском инсайдерских угроз, но 100% безопасности мешает тот же самый человеческий фактор и атаки типа «социальная инженерия», уязвимости нулевого дня и иные угрозы.

Вводим также целевое значение функции $F_{цел}$, которого необходимо добиться, чтобы риск был меньше заданного уровня в нужном диапазоне ущерба.

Вычисляем ошибку управления (ошибку обратной связи) на некотором шаге e_t по формуле 29:

$$e_t = F_{\text{цел}} - F_j(p_y, p_{cve}, p_{capec}) \quad (29)$$

Ошибка управления позволяет понять, насколько уровень вероятности, рассчитанной по функции, отклоняется от целевого значения, при котором будет достигаться необходимый уровень риска в нужном диапазоне ущерба [97].

Если $e_t>0$, значит нужно усиливать меры защиты и увеличивать $u_{i,t}$, если наоборот, то дальнейшего усиления не требуется. Поэтому исходя из этой ошибки обновляем управляющие воздействия $u_{i,t}$ по формуле 30:

$$u_{i,t+1} = u_{i,t} + e_t * F_j * \eta \quad (30)$$

где η – шаг обратной связи, который может принимать как фиксированное значение, так и переменное в зависимости от выбранной стратегии управления, поскольку если система работает в относительно стабильных условиях, можно задать фиксированное значение, если же важна точность или динамика среды быстро меняется, лучше использовать адаптивный вариант. Может принимать значения в диапазоне (0;1). Если шаг слишком большой – может возникнуть перерегулирование, в противном случае система будет медленно реагировать.

В данной формуле используются частные производные, поскольку $u_{i,t}$ является управляющим воздействием, влияющим на вероятность и соответственно на риск, а F_j - функция, зависящая от нескольких вероятностей. Поэтому функция F_j зависит от $u_{i,t}$.

Целью этих вычислений становится следующий результат (формула 31):

$$F_j(p_y, p_{cve}, p_{capec}) \rightarrow F_{\text{цел}} \quad (31)$$

Полученные формулы позволят моделировать изменение риска за шаг t (дискретное обновление, поскольку с помощью дискретного распределения происходит расчет успехов – целое число.

Данный расчет может осуществляться в отношении конкретного объекта, поскольку каждая огибающая распределения вероятностей моделирует риск, связанный с ним (уязвимостью, компонентом системы, сценарием атаки). В качестве объекта целесообразно рассматривать уязвимость, поскольку расчет идет с учетом её параметров и сама угроза может реализоваться за счет этой уязвимости. Получаем, что каждому объекту соответствует своя огибающая риска, рассчитанная через биномиальное распределение, зависящая от индивидуальных параметров: числа атак, вероятности реализации, уровня воздействия. Комплексную оценку риска при совмещении нескольких техник или угроз можно осуществить в двух случаях: при наступлении независимых событий и зависимых (случай, когда ущерб, наносимый при реализации второй угрозы, зависит от последствий реализации первой) [97-98].

В первом случае события независимы, тогда суммирование вероятностей реализации угроз по нескольким объектам обосновано тем, что каждый объект представляет собой отдельный вектор риска. Поскольку риски могут реализовываться независимо с возможной последующей нормировкой для сохранения вероятностной интерпретации.

Внедряя ущерб x, можно оценить риск следующим образом (формула 32):

$$Risk(x, n, F) = x * C_n^x F^x (1 - F)^{n-x} \quad (32)$$

Однако в этом случае мы можем иметь большой разброс значений рисков как на рисунке 16.

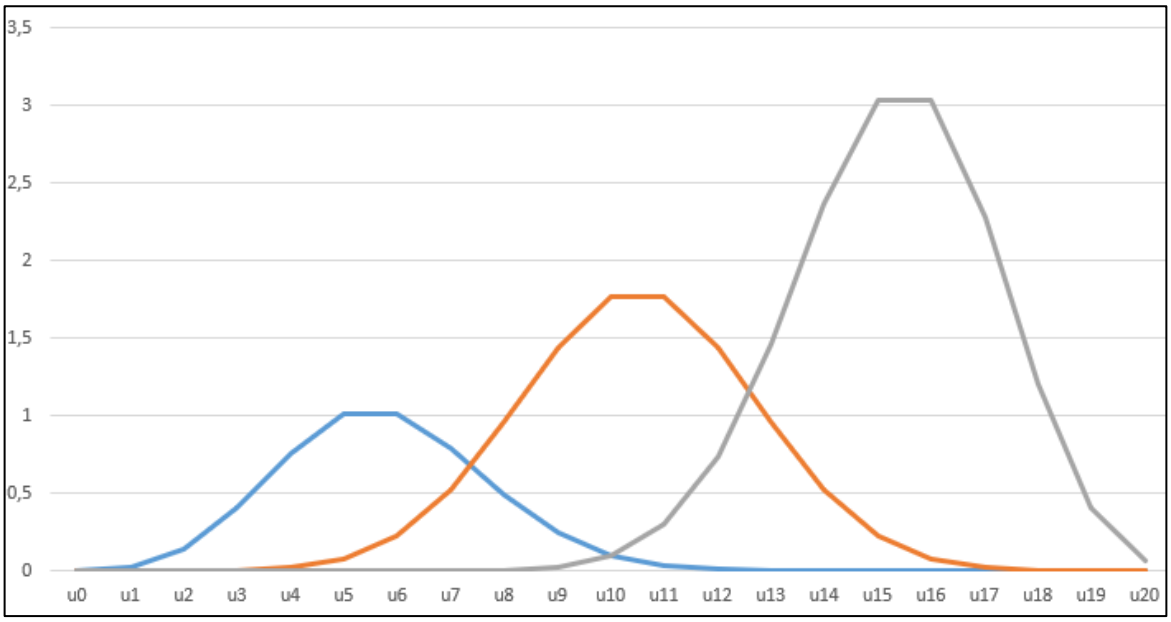


Рисунок 16 – Огибающие распределений с учетом ущерба x

Вместе с тем, возможно реализовать управление с целью уравнивания этих рисков по их максимальным величинам, поскольку считать параметр x ущербом возможно только в том случае, если ценность информационного ресурса всякого компонента равновелики. Отсюда ущерб равен x*Ci, где Ci – ценность защищаемого ресурса i-ой компоненты. Следуя этому свойству, целесообразно перераспределить ценность ресурса системы с учетом максимумов риска компонентов без учета этих ресурсов.

Расчет Ci осуществляется по формуле 33:

$$C_i = \frac{1}{p_i k_i} \frac{1}{\sum_{j=1}^{L} \frac{1}{p_j k_j}} \tag{33}$$

Отсюда стоит добиваться равенства (формула 34):

$$\max(p_1 * x_1 * C_1) = \ldots\ldots = \max(p_L * x_L * C_L) \tag{34}$$

После чего сложив несколько огибающих и перераспределяя Ci, мы можем получить следующий результат, представленный на рисунке 17 (при параметрах n=20, p1=0,25, p2=0,5; p3=0,75).

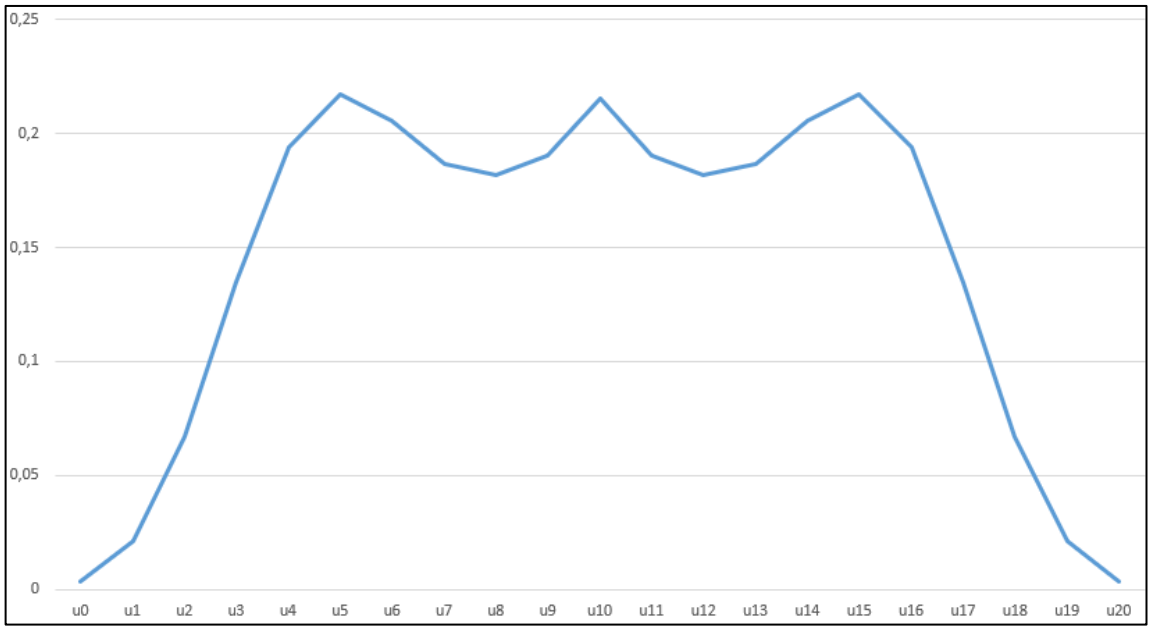


Рисунок 17 – Огибающая суммы

Графически итоговый результат с рисунка 17 можно получить из графиков, как представлено на рисунке 18 при тех же параметрах.

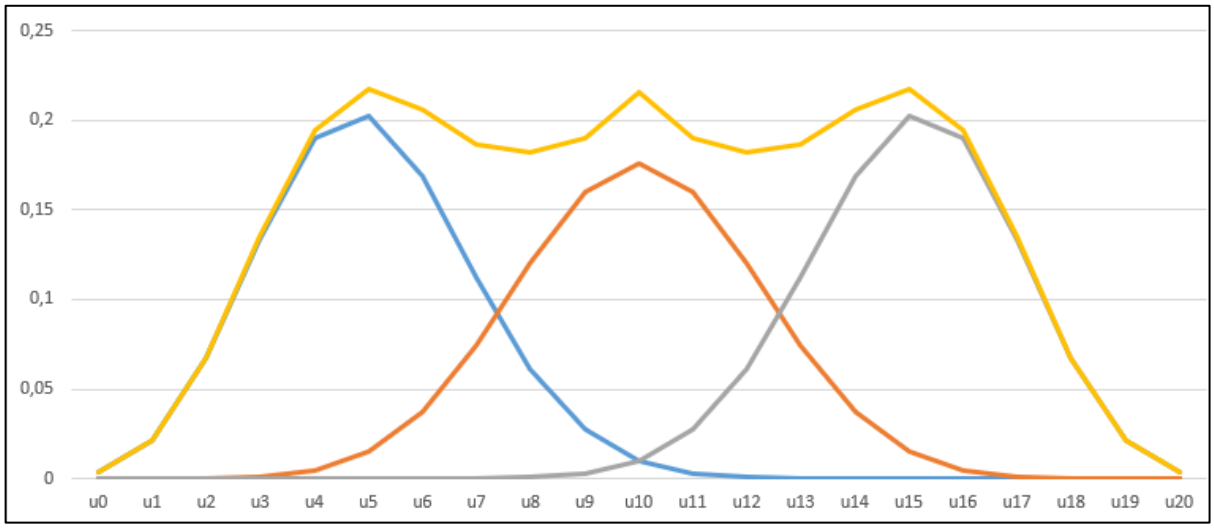


Рисунок 18 – Графики отдельных огибающих и суммарный

Это достигается за счет следующей формулы 35:

$$Risk_{total} = \sum_{j=1}^{L} Risk_j \quad (35)$$

где L – количество объектов;

P_{total} – суммарный риск по всем объектам.

Однако при таком расчете получаем, что сумма рисков превышает 1, что не может быть, поэтому чтобы сохранить интерпретацию результата как вероятностного распределения, его необходимо нормировать. Поэтому получаем следующую формулу 36:

$$Risk_{total}^{norm} = \frac{1}{L} \sum_{k=1}^{L} Risk_j \quad (36)$$

Тогда получаем следующий нормированный график распределения (рисунок 19).

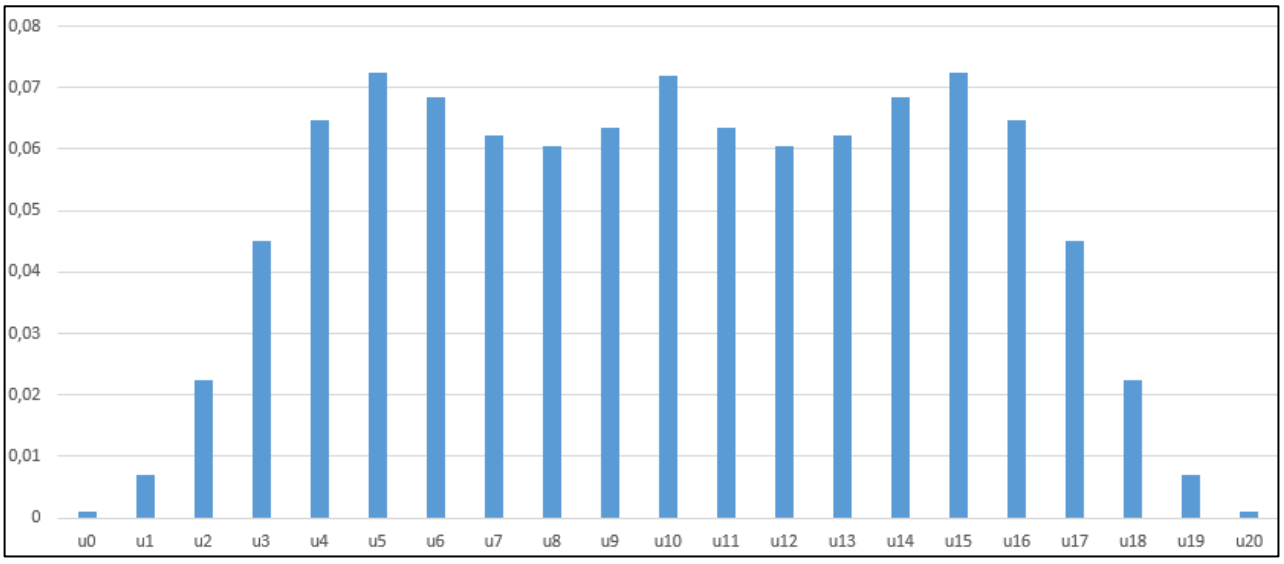


Рисунок 19 – Нормированное распределение суммы вероятностей

Получаем следующую методику регулирования риском (рисунок 20):

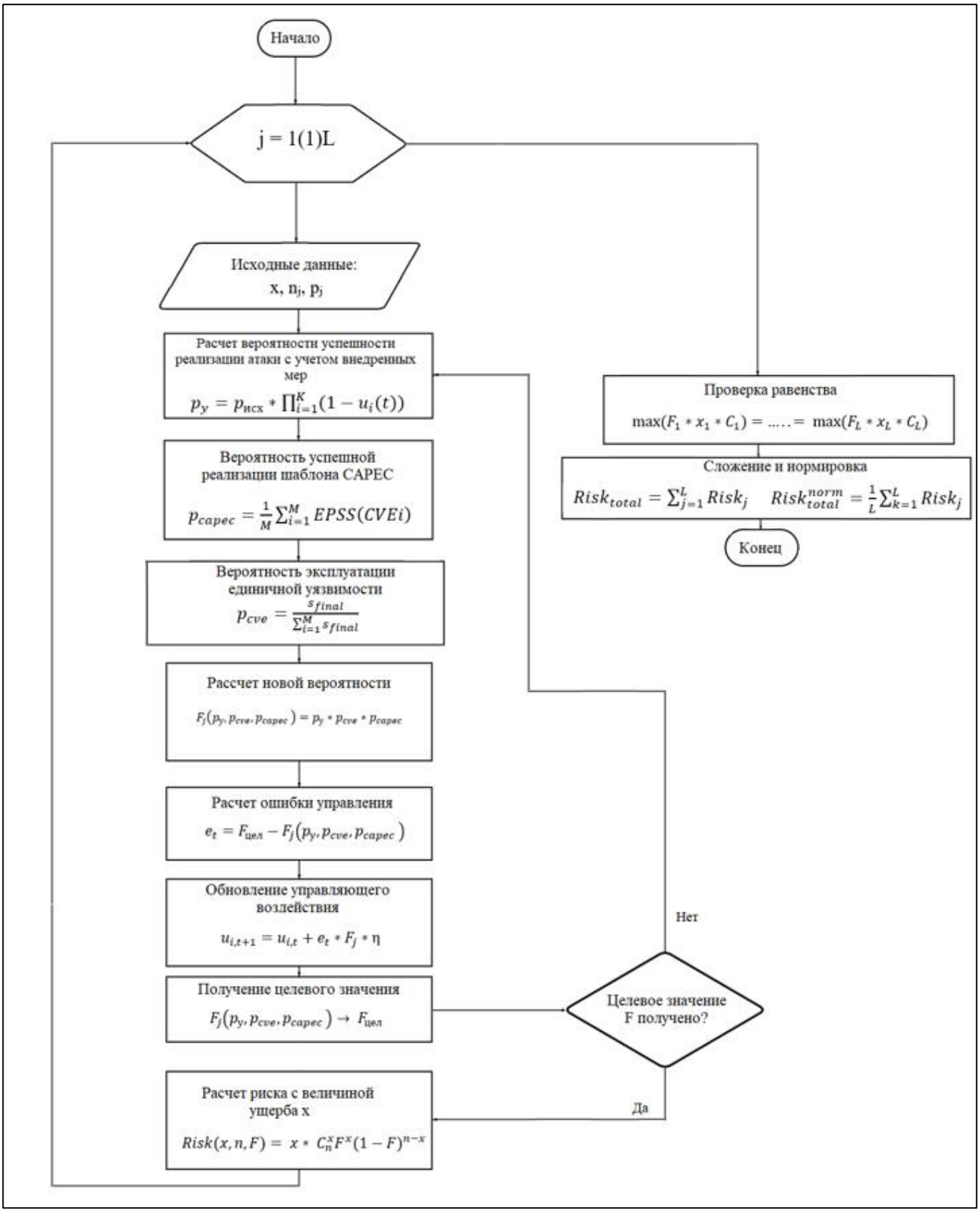


Рисунок 20 – Методика регулирования риска

3.2 Регулирование риска с использованием гипергеометрического распределения

3.2.1 Обоснование выбора гипергеометрического распределения и выбор регулируемого параметра

Гипергеометрическое распределение удобно использовать для анализа рисков и последствий, связанных с ограниченными выборками без возвращения, то есть в ситуациях, когда имеется фиксированный набор объектов и выбираются подмножества без «возвращения» или повторного использования. При этом в отличие от биномиального распределения, где целесообразно использовать непрерывное время t для оценки плавного изменения вероятности, гипергеометрическое распределение опирается на фиксированные, дискретные величины. Данное распределение имеет вид (формула 37) [70]:

$$p(x; n, k, m) = \frac{C_k^x C_{n-k}^{m-x}}{C_n^m}; x \leq k; m - x \leq n - k \quad (37)$$

где x – число успешных атак на критичные уязвимости;

n – общее число уязвимостей;

k – число критичных уязвимостей, которые могут привести к серьезным последствиям;

m – число совершенных атак на уязвимости (выборка).

В самой формуле мы имеем следующее:

C_k^x – число способов реализации x успешных атак на k критичных уязвимостей;

C_{n-k}^{m-x} – число способов реализации m-x атак на некритические уязвимости из n-k доступных;

C_n^m – общее число способов реализации m атак из n уязвимостей.

Данное распределение может быть использовано при изучении «слепой атаки» – сценария, при котором злоумышленник не располагает информацией о конфигурации системы и возможных точках компрометации, и потому осуществляет

атаки на случайно выбранные уязвимости, рассчитывая на попадание в критичные. Подобная атака может моделироваться с помощью гипергеометрического распределения, поскольку выборка осуществляется без возвращения и без априорного знания о наличии «критичных уязвимостей». Схема реализации «слепой атаки» представлена на рисунке 21 [98-103].

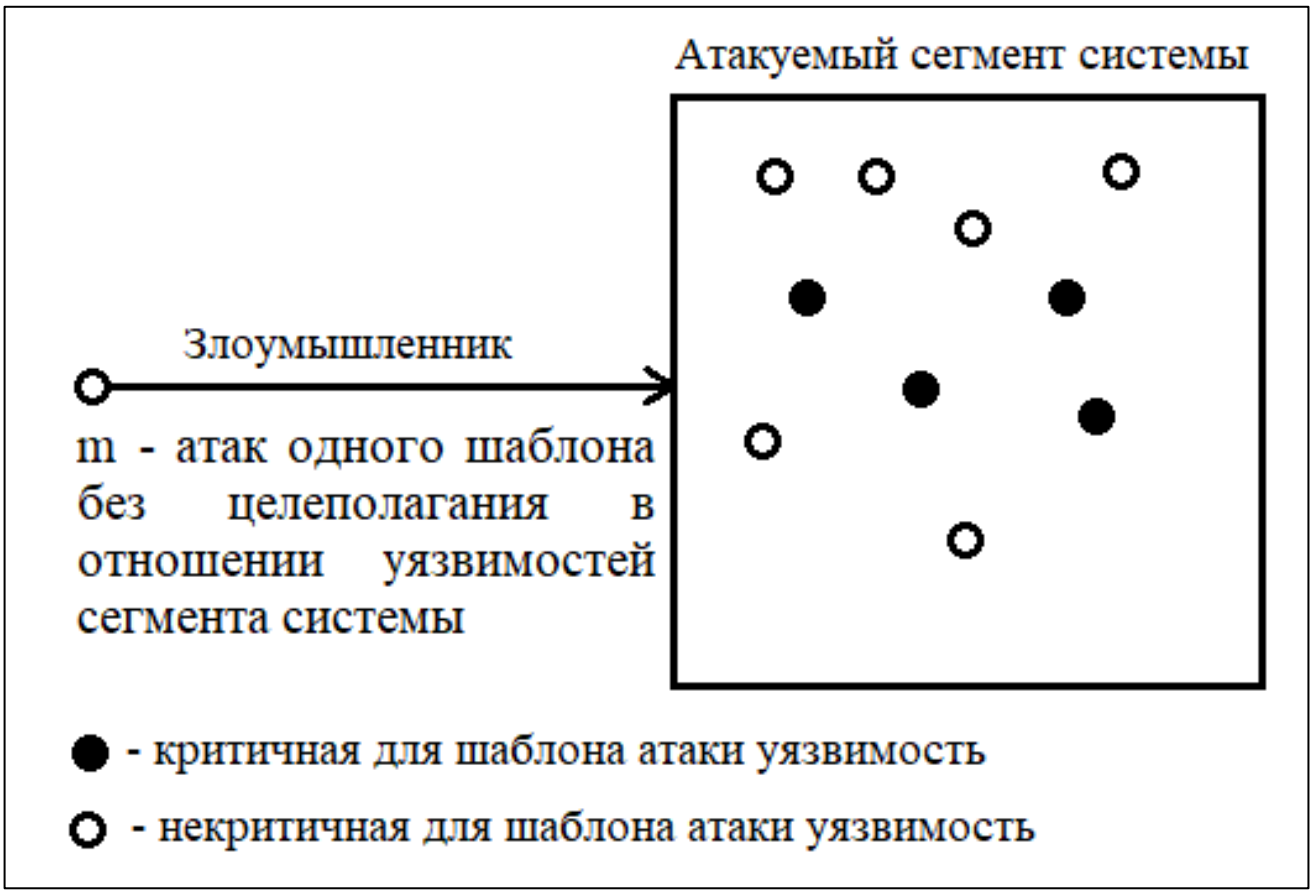


Рисунок 21 – Схема реализации «слепой атаки»

Анализируя ограничения гипергеометрического распределения, можно отметить, почему они могут выполняться в рамках обеспечения информационной безопасности:

x<=k – данное условие означает, что нельзя реализовывать в атаке больше критичных уязвимостей, чем было совершено атак;

m-x<=n-k – данное условие означает, что число атак на некритические уязвимости (m-x) не превышает их доступное количество n-k.

Закрыть все уязвимости проблематично, поскольку это требует:

– времени на анализ и тестирование;

– качественных специалистов, которые являются наиболее редким ресурсом ввиду мирового дефицита, превышающего 3 миллиона человек. Спрос на таких специалистов растет с большим темпом, по сравнению с интенсивностью появления новых кадров. Трудностью также является необходимость в глубоких знаниях, высокой квалификации, требующей много лет опыта работы. Поэтому специалисты в сфере кибербезопасности должны обладать многопрофильной подготовкой;

– денег на обновление, на новые средства защиты информации [78-79].

Даже если известно, что на текущий момент «закрыты» все уязвимости на следующий день может выйти обновленная версия программного обеспечения с новыми критичными уязвимостями, или же злоумышленники могут найти новые в той же версии.

Само количество атак m должно быть меньше количества критичных уязвимостей k, поскольку если m>k, то часть атак не может попасть в критичные уязвимости ввиду недостаточности целей. Более того, вероятность «успешных» атак при большом m будет искажена и переоценена.

Критичные уязвимости – объекты, через которые может быть реализована атака. Если последних больше, чем уязвимостей вообще, то имеем ситуацию, когда атаки «бьют» в пустоту (в реализованные уязвимости) или не учитывается ограниченность возможностей атакующих, что маловероятно в условиях защищенной ИС.

Анализируя эти параметры, можно сделать вывод, что специалист по ИБ может повлиять только на параметр k, поскольку x – стохастическая величина, характеризующаяся числом успешных атак, n – общее число уязвимостей, определяемое исходным состоянием системы (обычно зафиксировано технической архитектурой ПО), m – количество атак, определяемое действиями противника. Возвращаясь к k, ИБ-специалист может управлять количеством критичных уязвимостей, устраняя уязвимость, снижая её доступность. Однако уменьшая/увеличивая число критичных уязвимостей k, соответственно изменяется и общая генеральная совокупность n. Это может происходить в результате появления

новых обновлений, которые обеспечивают фикс старых уязвимостей и появление новых из-за возможных ошибок разработчика.

Генеральная совокупность уязвимостей включает в себя k критичных и n-k уязвимостей, не являющимися таковыми для безопасности системы. Последний тип уязвимостей не приводит к серьезным последствиям, имеет низкую вероятность эксплуатации, могут быть оставлены открытыми без риска для функционирования.

Так, регулируя параметр k, можно смещать график распределения в нужную сторону, как представлено на рисунке 22 (оранжевый график k=15, синий k=35).

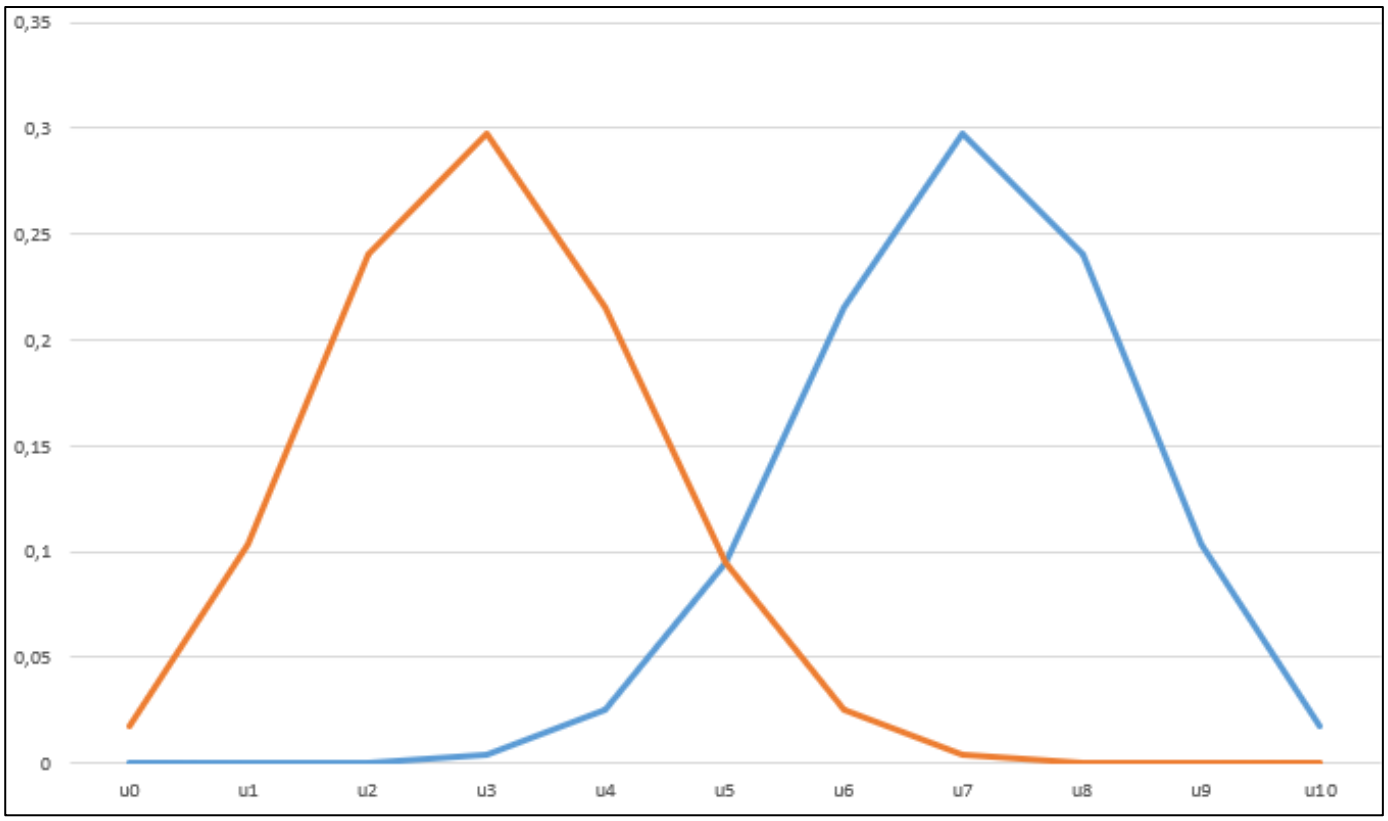


Рисунок 22 – Гипергеометрическое распределение при разных параметрах k

3.2.2 Методика регулирования риска с использованием гипергеометрического распределения

Специалист не может корректировать критичность уязвимости, поскольку это является внешне заданным статистическим параметром, определяемым

калькуляторами CVSS, OWASP, EPSS, а не тем, что может напрямую изменить специалист по ИБ, поэтому единственным способом корректировки этого параметра является не уменьшение критичности какой-то конкретной уязвимости, входящей в это множество, а деятельность через её окружение и контекст эксплуатации. Такая деятельность может подразумевать ограничение сетевого доступа, удаление программного компонента, отключение сервисов и служб, сегментация. Иными словами, уязвимость по-прежнему критична, но исключена из атакуемого множества, и потому не входит в n [97].

Помимо этого, целесообразно накладывать дополнительные механизмы, делающие уязвимость непригодной для эксплуатации или рассматривать только те уязвимости, которые могут быть эксплуатируемы в текущей архитектуре.

С точки зрения извлечения без возвращения гипергеометрическое распределение должно быть учтено при исключении уязвимостей:

– проэксплуатируемых, чтобы не предоставить злоумышленнику повторную возможность успешной атаки;

– некритичных, но уже выявленных, для которых злоумышленник может найти подходящий шаблон атаки.

Однако в рамках регулирования возникает необходимость учитывать ограничения ресурсов, затрачиваемых на управление числом критичных уязвимостей. С этой целью введем понятия энергии управления как агрегированной меры на реализацию управляющих воздействий.

Энергия управления (E) – мера затрат или усилий, необходимых для того, чтобы изменить состояние системы и привести её к цели. В данном случае необходимо привести исходную систему к состоянию, при котором уровень риска в заданном диапазоне не превышает заданного. То есть энергией управления является метафора затрачиваемых ресурсов, что делает задачу более реалистичной.

Необходимо также помнить, что управляющее воздействие в модели регулирования риска – любое целенаправленное действие, снижающее риски наступления ущерба за счет уменьшения k_t. Поэтому на него целесообразно вводить ограничение, связанное с доступной энергией управления (бюджет, часы экспертов).

Ограничение позволит не перезагружать частыми действиями систему, сохранять ресурсы. Его можно представить в виде формулы 38 [97].

$$\sum_{t=0}^{T}|u_t| \leq E_{max} \quad (38)$$

При построении системы защиты используется формальная экстраполяция, то есть прогнозирование угроз и рисков на основе формализованных моделей и текущих данных, с целью предварительного построения или корректировки системы защиты еще до наступления событий. Это позволит наблюдать динамику в будущем, основываясь на предположении, что текущие тенденции будут продолжаться. При процессе моделирования введем прирост числа критичных уязвимостей λt (появление новых критичных уязвимостей) и снижение их числа μt – величины, которые будут неизменными в процессе последующей эксплуатации защищенной информационной системы.

Параметр λ_t можно рассчитать следующим образом (формула 39):

$$\lambda_t \approx \Delta k_t^+ \quad (39)$$

Получаем положительный прирост количества уязвимостей Δk_t^+ за шаг t.

Параметр μ_t можно рассчитать следующим образом (формула 40):

$$\mu_t \approx \Delta k_t^- \quad (40)$$

Получаем количество устраненных уязвимостей Δk_t^- за шаг t без учета управляющего воздействия u_t.

Сами переменные лежат в следующих диапазонах:

$\lambda_t \in [0, n\text{-}k_t]$, при этом максимум достигается, если все имеющиеся оставшиеся уязвимости из общего числа становятся критичными на текущем шаге [97];

$\mu_t \in [0, k_t]$, максимум достигается, если все текущие критичные уязвимости устраняются без участия управления.

Относительно разного поведения переменных может реализовываться регулирование риска, смещая график и соответственно значение риска в меньшую сторону или большую. С учетом этих параметров и управляющего воздействия u_t получаем следующее выражение (формула 41):

$$k_{t+1} = k_t + \lambda_t * u_t - \mu_t * u_t \quad (41)$$

Значение управляющего воздействия лежит в диапазоне от 0 до 1:

u_t=0 – нет управления, система развивается «естественным образом» (появление уязвимостей не подавляется, устранение не ускоряется);

u_t=1 – максимальное управление (ресурсы максимально брошены на контроль и устранение.

Если необходимо уменьшать значение k_t для увеличения уровня риска при меньших значениях ущерба, необходимо, чтобы число критичных уязвимостей снижалось, что может осуществляться за счет следующих действий:

u_t – активно управляем за счет контроля критичных уязвимостей, внедрения патчей [97];

λ_t – прирост числа критичных уязвимостей нужно стараться держать низким за счет превентивных мер, предиктивного анализа;

μ_t – рост данного параметра помогает снижению k_t.

Таким образом имеем два контролируемых параметра u_t и μ_t, которые и вносят основной вклад в снижение риска, компенсируя λ_t.

Имеем и обратную ситуацию – контролируемо увеличить k_t, чтобы перераспределить риск и сделать его менее концентрированным. В таком случае имеем следующее поведение переменных:

k_t – необходимо целенаправленно увеличивать, не запуская ситуацию (держа все под контролем), для получения нового значения на следующем шаге;

u_t – целенаправленно временно ослабляем управляющее воздействие;

λ_t – прирост числа критичных уязвимостей обусловливается внедрением нового кода, расширением зон сканирования [97];

μ_t – параметр стабилен, мал, при этом не мешает росту k_t.

Чтобы избежать перерасход энергии необходимо контролировать ожидаемый остаток энергии на каждом шаге. Тогда получаемый остаток выходит из следующей формулы 42:

$$E_{\text{ост}} = E_{max} - \sum_{t=0}^{T} |u_t| \quad (42)$$

При этом целесообразнее связать управляющее воздействие u_t с параметрами положительного и отрицательного прироста количества критичных уязвимостей и ввести соответствующие коэффициенты α, $\beta \in [0,1]$ — коэффициенты чувствительности управления к интенсивностям. Эти коэффициенты определяются априорно для разных классов систем и меняются редко и сложно. Получаем, что, регулируя λ_t, μ_t, u_t, можем регулировать итоговую переменную k_{t+1}.

Тогда получаем следующую формулу расчета k_{t+1} (формула 43):

$$k_{t+1} = k_t + \lfloor \lambda_t * (1 - \alpha u_t) \rfloor - \lfloor \mu_t * (1 + \beta u_t) \rfloor \quad (43)$$

где $\lambda_t * (1 - \alpha u_t)$ – чем больше управление, тем меньше темп появления уязвимостей;

$\mu_t * (1 + \beta u_t)$ – чем больше управление, тем больше темп устранения уязвимостей [97].

При этом, если $\alpha = 0$, то при даже при максимальном управлении 1 никакого влияния на появление уязвимостей нет, если же $\alpha = 1$, то при $u_t = 1$ прирост уязвимостей может быть полностью подавлен. Управление способствует понижению интенсивности появления уязвимостей.

В случае с β, если β = 0, управление не ускоряет устранение, если β = 1, при $u_t = 1$ снижение (отрицательный прирост) удваивается. Управление увеличивает скорость устранения уязвимостей.

Если в рамках работы над биномиальным распределением целесообразно было рассматривать отдельные уязвимости в качестве объектов, то в случае гипергеометрического распределения можно рассматривать систему, содержащую уязвимости или несколько сегментов системы, так же содержащие уязвимости.

Эти сегменты можно считать независимыми друг от друга, поскольку каждый сегмент может обслуживать разные процессы, сервисы и отделы, иметь свой набор уязвимостей. Если атака на один сегмент не влияет напрямую на другой, то события (согласно теории вероятностей) можно считать независимыми. Внутренние политики также могу делать сегменты условно-изолированными. Поэтому, целесообразно агрегировать риск по нескольким объектам или сегментам. Однако, если появятся взаимосвязи между сегментами (атака на один сегмент открывает возможность для атаки на другой), то целесообразно переходить к совместным распределениям или моделям с зависимостями, поскольку простое сложение не будет отражать реальную картину [97].

Считая x величиной нормированного ущерба, можно оценить риск по формуле 44:

$$Risk = x\frac{C_k^x C_{n-k}^{m-x}}{C_n^m} \tag{44}$$

где x=1(1)10.

Однако в этом случае мы можем иметь большой разброс значений рисков как на рисунке 23.

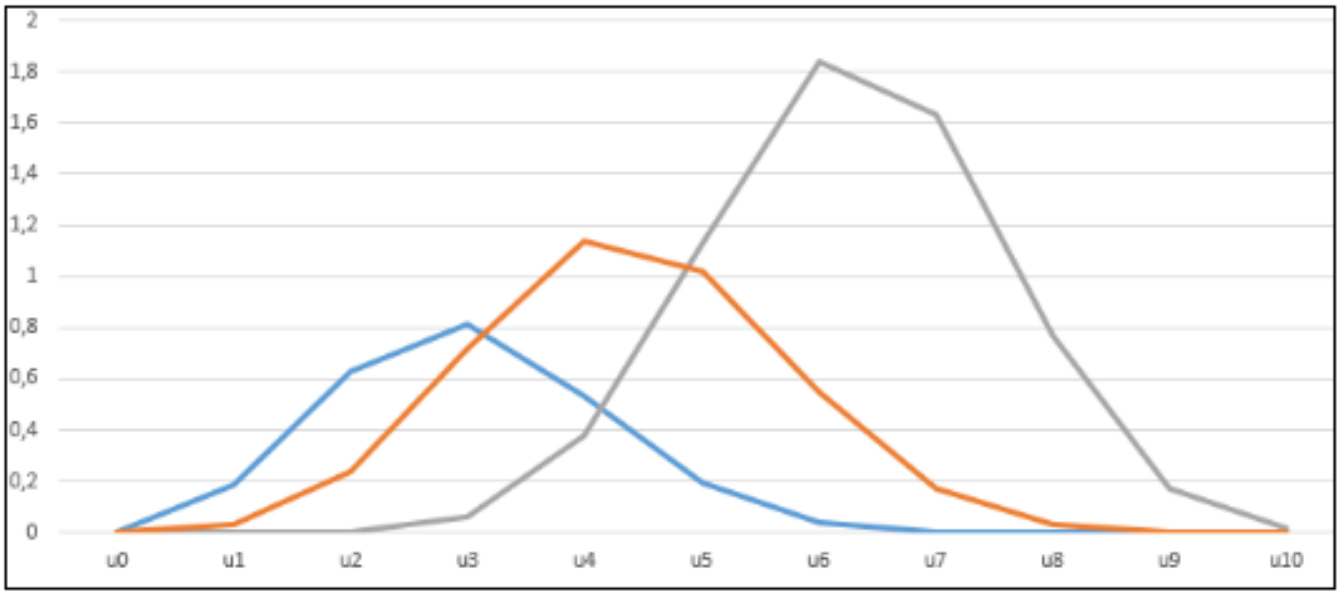


Рисунок 23 – Огибающие распределений с учетом ущерба x

Считая x ущербом, вводим дополнительно величину α_i, отвечающую за долю потерь защищаемого i-го сегмента. Этот параметр может служить локальным инструментом чувствительности, учитывающим специфику конкретного сегмента, что также позволяет решить вопрос с перекосом в системе обеспечения безопасности (рисунок 3).

Отсюда ущерб будет равен $x*\alpha_i$. При перераспределении доли потерь можно оценить влияние каждого сегмента на суммарный риск.

При перераспределении огибающие примут вид, как это показано на рисунке 24.

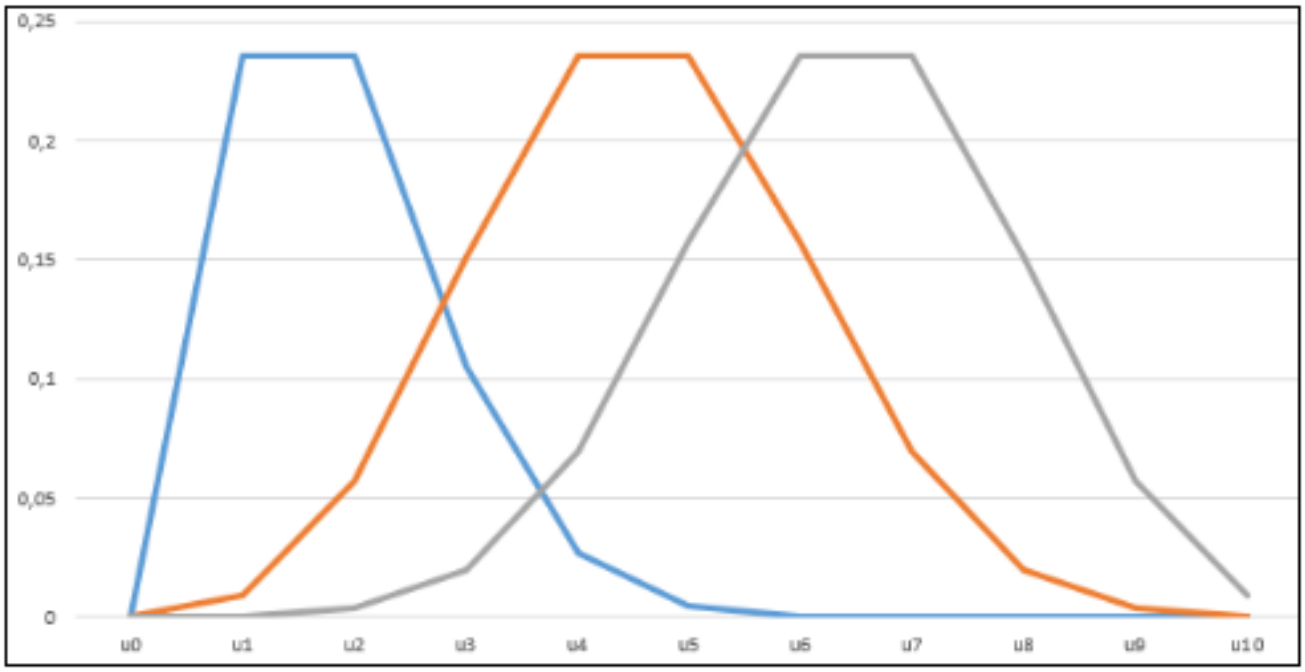


Рисунок 24 – Огибающие распределений с учетом ущерба x*αi

Работая с суммарным риском, вводим дополнительно C_j – ценность ресурса, при реализации x_j – числа реализованных атак ($j = 0(1)m_i$), перераспределяя который огибающие примут необходимый вид.

Тогда суммарный риск рассчитывается по формуле 45:

$$Risk_{total} = \sum_{j=1}^{m}(Cj \sum_{i=1}^{L} Risk_{ij}) \quad (45)$$

где L – количество объектов (сегментов сети).

Графически итоговый результат представлен на рисунке 25.

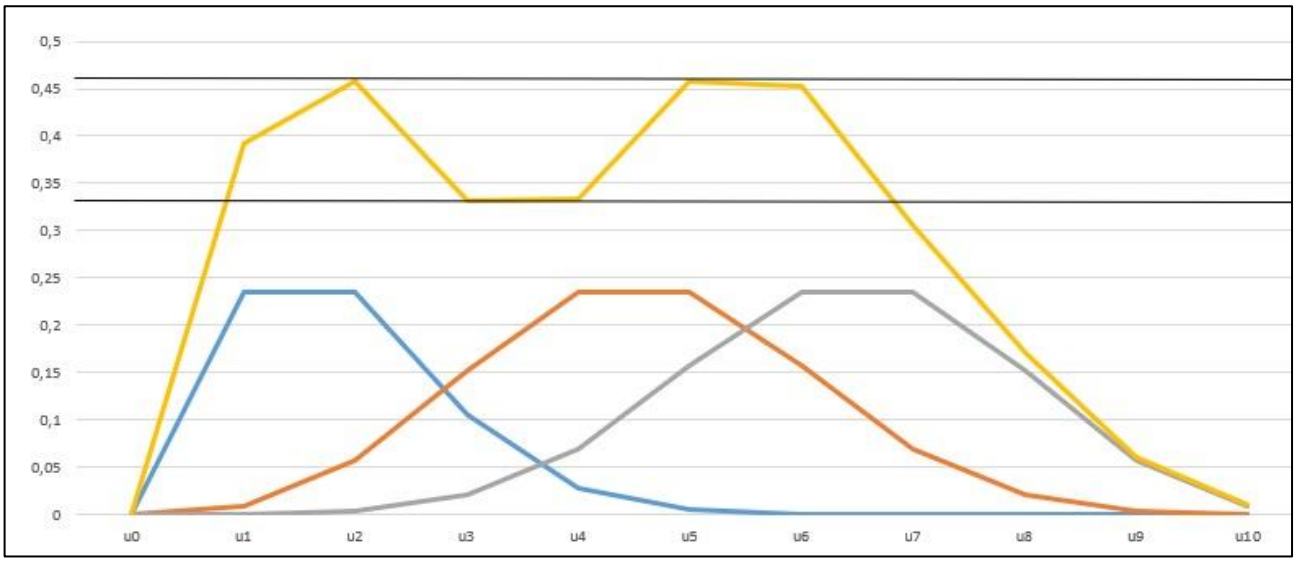


Рисунок 25 – Огибающие распределений (отдельных огибающих и суммарный)

Однако при таком расчете получаем, что сумма вероятностей превышает 1, что не может быть, поэтому чтобы сохранить интерпретацию результата как вероятностного распределения, его необходимо нормировать. Поэтому получаем следующую формулу 46:

$$Risk_{total}^{norm} = \frac{1}{L}\sum_{z=1}^{L} Risk_z \quad (46)$$

Нормировка позволит корректно сравнить риски разных событий и сделать осмысленные выводы. Более того, если вероятности не нормированы, ожидаемый риск может быть завышен или занижен из-за некорректных весовых коэффициентов. Многие математические методы предполагают работу с нормированными распределениями. Ненормированные данные могут привести к численной неустойчивости или ошибкам в дальнейших расчетах.

Регулирование осуществляется за счет перераспределения C_j и корректировки параметров самого распределения. Имея исходную агрегированную огибающую, возвращаемся к её составляющим, меняем параметры распределений, агрегируем их и перераспределяем Ci для поддержания риска в заданном диапазоне.

В итоге получаем методику с использованием принципа обратной связи, основанный на динамическом обновлении параметра k_t на каждом шаге времени t с учётом текущего состояния системы (k_t), положительного и отрицательного прироста (λ_t, μ_t), управляющих воздействий (u_t), которые как раз и корректируют эти величины. Данный принцип позволяет регулировать и динамически балансировать систему в реальном времени через u_t.

Предложенный подход ближе к реальным условиям функционирования информационных систем, где уязвимости могут устраняться, а меры защиты адаптироваться к изменяющимся угрозам.

Методика позволяет обеспечить пошаговое регулирование, выстроить цепочку управляющих воздействий, определить сколько усилий нужно потратить, чтобы удержать систему в безопасной зоне и при ограниченности ресурсов минимизировать E, не выходя за допустимые значения ущерба**.**

Помимо регулирования уровня риска данную методику можно применить для управления защищенности, понимаемой, как состояние объекта или системы, при котором риск наступления ущерба остается в допустимых границах. Управление защищенностью в рамках рассматриваемой методики означает – поддержание количества уязвимых элементов k_t, перераспределение риска в сторону меньших ущербов.

Таким образом, сама методика регулирования рисков с использованием гипергеометрического распределения можно представить следующим образом (рисунок 26):

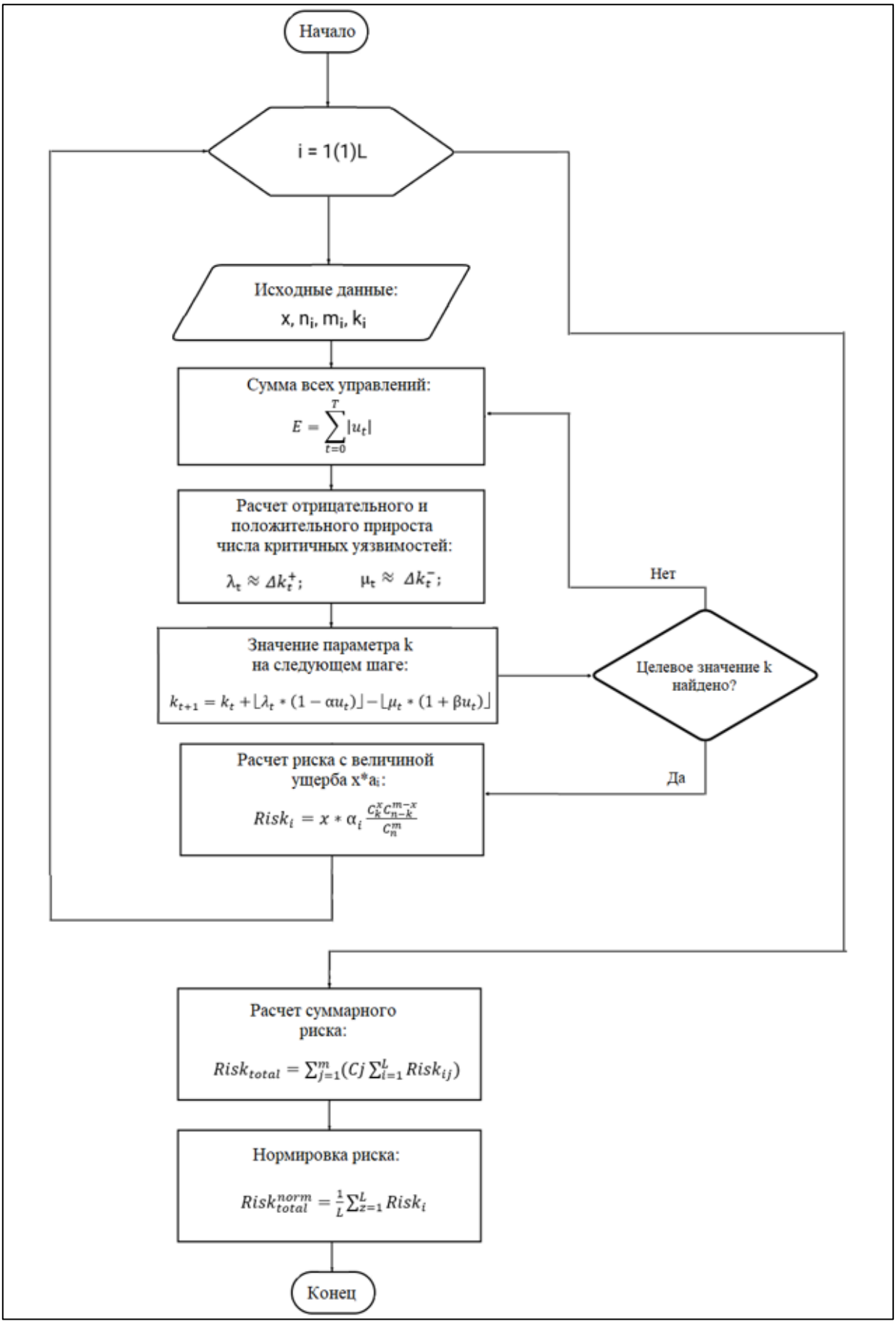


Рисунок 26 – Методика регулирования риска

Приведем пример использования методики.

Исходная ситуация: пусть на предприятии имеется информационная система, включающая 3 сегмента, каждый из которых имеет определенное число уязвимостей.

Сегмент 1: n1=50, k1=35, m1=10.

Сегмент 2: n2=40, k2=26, m2=12.

Сегмент 3: n3=50, k3=15, m3=10.

Ставится задача, снизить риск в диапазоне $[u_6\text{-}u_{10}]$ до 0,1.

Тогда исходное распределение вероятностей этих трех объектов имеет вид (рисунок 27)

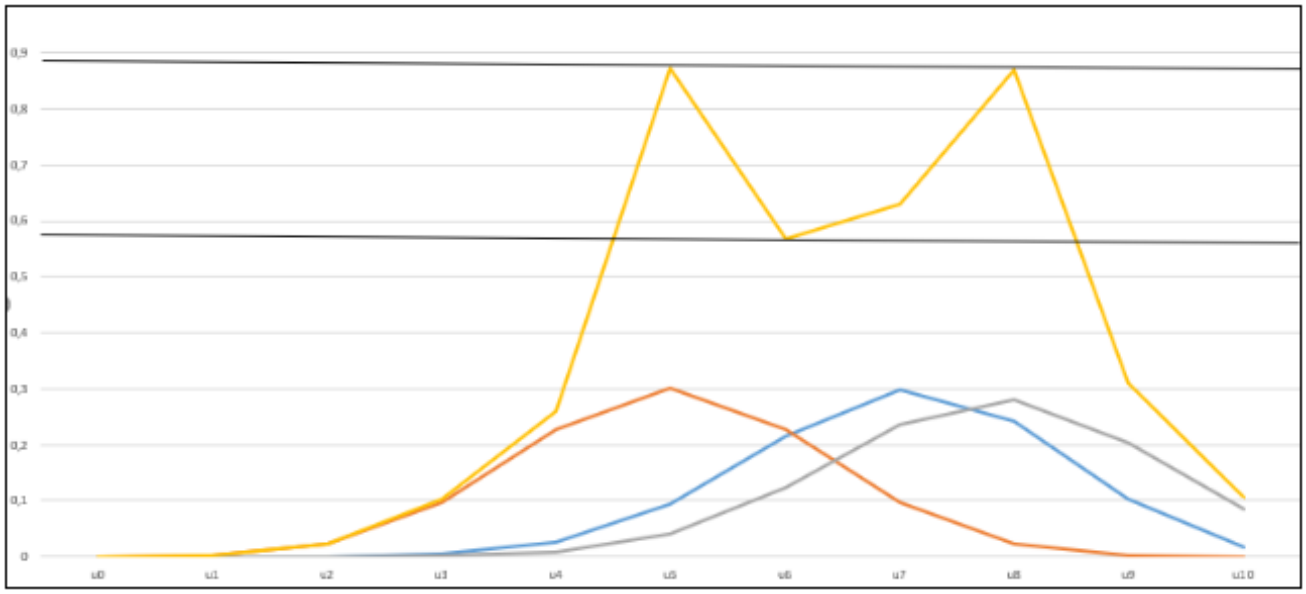


Рисунок 27 – Огибающие распределений вероятностей объектов

Где синий график - первый сегмент, оранжевый график – второй сегмент, серый график третий сегмент. Таким образом, можно сделать вывод, что ключевыми объектами регулирования у нас будет 1 и 3 сегмент.

Определим стартовые показатели, при которых достигается равенство $k_{t+1} = k_t$:

Сегмент 1: α =0,4; β=0,3;u_t=0,5; λ_t=5, μ_t=4.

Сегмент 2: α =0,1; β=0,2;u_t=0,4; λ_t=5, μ_t=4.

Сегмент 3: α =0,2; β=0,1;u_t=0,3; λ_t=5, μ_t=4.

Имея стартовые параметры, переходим к их регулированию. По имеющемуся графику целесообразно начать с первого сегмента.

Попробуем подобрать такие значения параметров, при которых можно было бы получить нужное значение k_t - α =0,1; β=0,3; u_t=0,8; λ_t=5, μ_t=25.

Тогда k_{t+1}= 35 + ⌊5*(1-0,8*0,1) ⌋ - ⌊25*(1-0,8*0,3) ⌋ = 35+4-31=8, что не подходит по имеющимся условиям. Уменьшим μ_t до 24, u_t до 0,5, а λ_t увеличим до 8.

Тогда k_{t+1}= 35 + ⌊8*(1-0,5*0,1) ⌋ - ⌊24*(1-0,5*0,3) ⌋ = 35+7-27=15.

Получаем новое значение k_t для первого сегмента, тогда огибающая примет вид (рисунок 28)

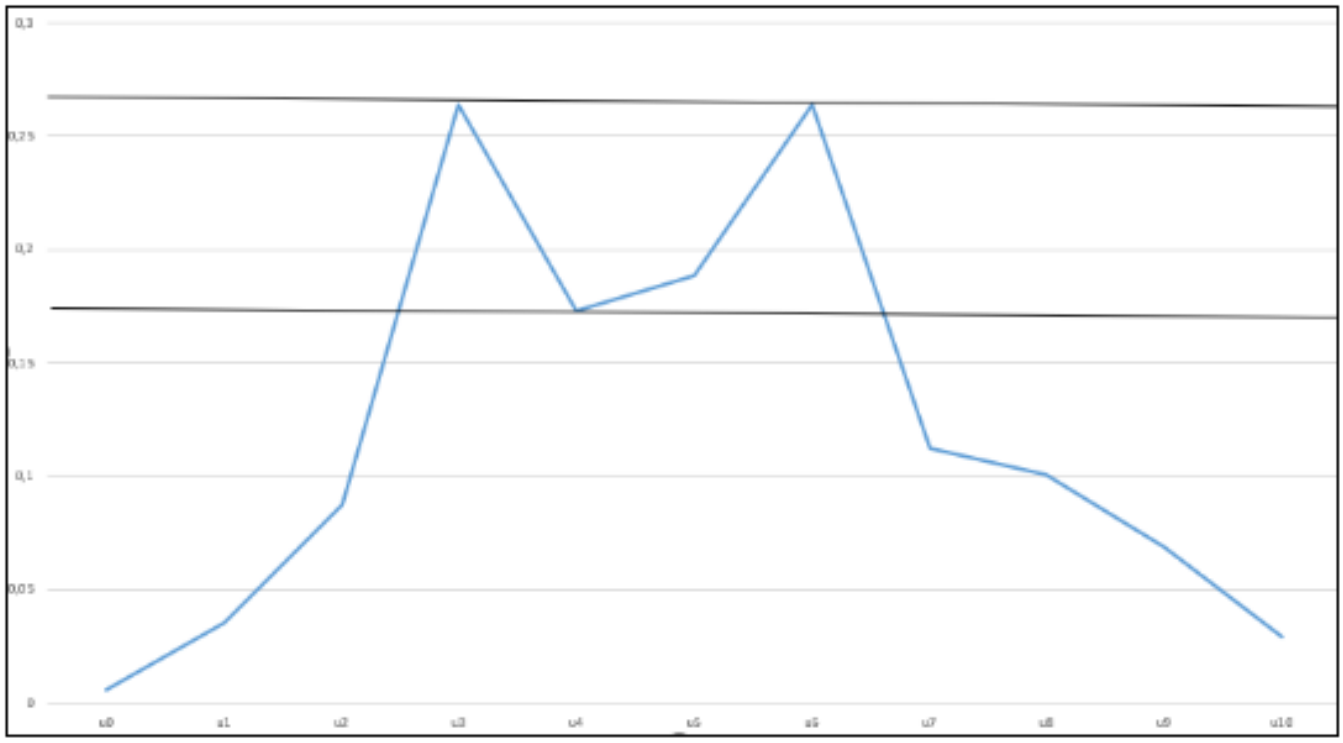


Рисунок 28 – Огибающая после изменения параметров 1 сегмента

Тогда в диапазоне [u_8-u_{10}] уровень риска меньше 0,1. Это достигается тем, что интенсивность λ довольно высокая, но управляющее воздействие частично подавляет его через коэффициент α, устранение уязвимостей очень активное за счет высокой μ_t и чувствительности 0,3, которая усиливает эффект управляющего воздействия. При этом управление увеличивает скорость устранения на 15%, что дает итоговое устранение 27. Получаем, что мы «подавили» 27 уязвимостей и допустили 7 новых,

что приводит к k_t = 15. Данный параметр может быть получен как за один шаг, так и за несколько в рамках одного сегмента.

Переходим к 3 сегменту, для достижения необходимого результата нужно получить k_t=13. Это может быть реализовано при параметрах α =0,1; β=0,3; u_t=0,5; λ_t=6, μ_t=15, тогда: k_{t+1}= 25 +⌊6*(1-0,5*0,1) ⌋-⌊15*(1-0,5*0,3) ⌋=26+6-18=13.

Тогда огибающая примет вид (рисунок 29):

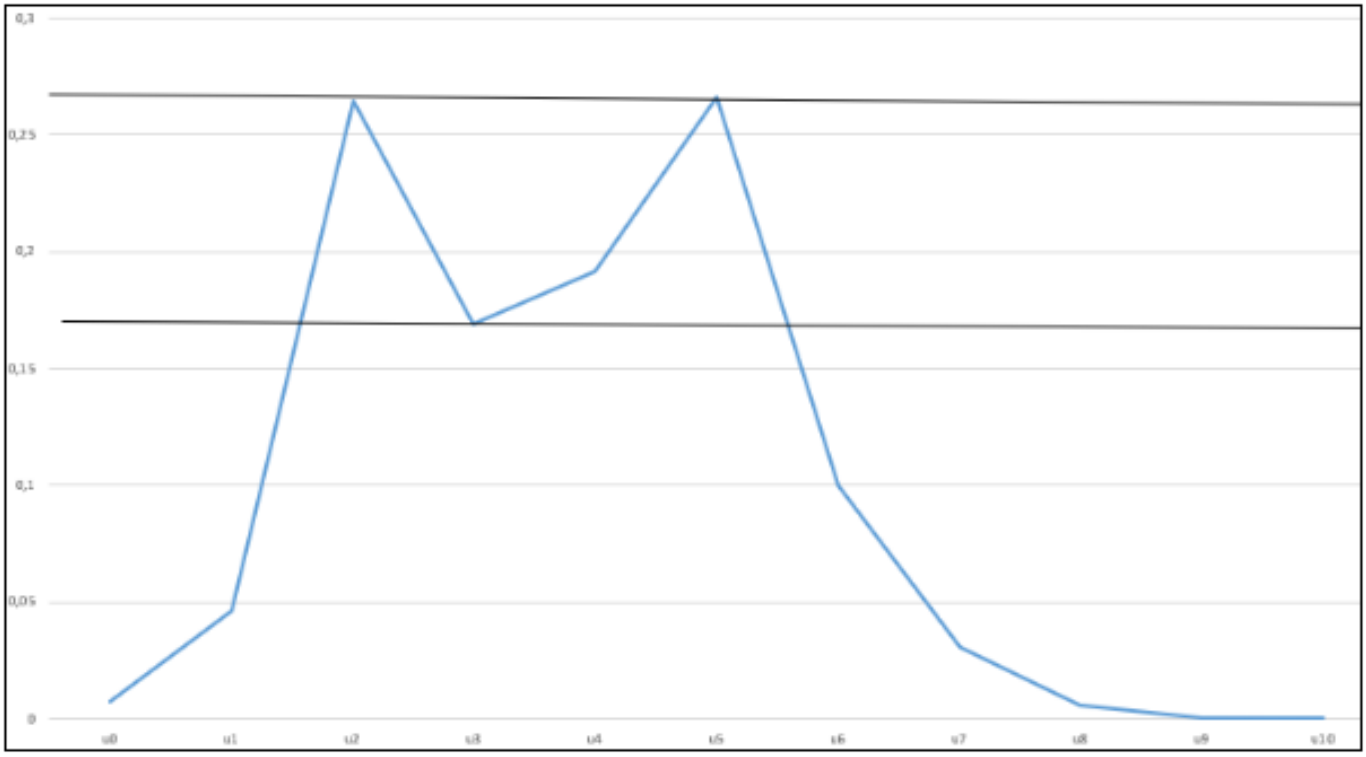


Рисунок 29 – Огибающая после изменения параметров 3 сегмента

Получаем, что только при u_6 уровень риска немного превышает 0,1, поэтому переходим ко 2 сегменту. Для достижения необходимого результата нужно получить k_t=14. Это может быть реализовано при параметрах α =0,1; β=0,3; u_t=0,5; λ_t=2, μ_t=2, тогда: n_{t+1}= 25 +⌊2*(1-0,5*0,1) ⌋-⌊2*(1-0,5*0,3) ⌋=15+1-2=13.

Суммарная энергия управления будет составлять 1,5 в результате имеющихся переходов.

Получаем, что в заданном диапазоне ущерба уровень риска меньше 0,1.

Имеющийся пример позволяет понять, как обеспечивать пошаговое регулирование, выстраивать цепочку управляющих воздействий, определить сколько усилий нужно потратить, чтобы удержать систему в безопасной зоне и при ограниченности ресурсов минимизировать E, но не выходить за допустимые значения ущерба.

Итогами данного раздела являются предложенные методики регулирования риска, основанные на параметрическом управлении вероятностями наступления ущерба с использованием биномиального и гипергеометрического распределения. Эти методики позволяют учитывать дискретную природу киберугроз, варьировать уровень риска за счет проектных параметров и обеспечивают более гибкий и обоснованный подход к управлению ИБ.

ЗАКЛЮЧЕНИЕ

Таким образом, в ходе исследования удалось глубоко погрузиться в тематику управления рисками реализации кибератак.

В порядке разрешения противоречий между объективной потребностью в универсальной структуре процесса управления рисками, способной охватывать широкий спектр угроз, и разнообразием практических сценариев реализации кибератак, делающих применение унифицированного подхода затруднительным, была собрана и систематизирована информация о существующих подходах и методах управления рисками реализации кибератак на основе анализа интернет-источников, обладающая следующей новизной, практической ценностью и теоретической ценностью:

– впервые предложен структурированный подход к систематизации знаний в области управления рисками, позволяющий динамически обновлять базу подходов и практик;

– систематизация информации по существующим подходам и методам управления рисками позволит расширить и структурировать существующие знания в области управления рисками информационной безопасности, сформировать основу для построения математических моделей, учитывающих вероятностный характер угроз;

– систематизация информации на основе анализа открытых источников позволит разработать структурированную базу знаний о современных методах управления рисками, которую можно применить в аналитических центрах, при разработке нормативных документов.

В порядке разрешения противоречий между спецификой практических ситуаций, определяющих форму распределения риска, и необходимостью универсального выбора вероятностной модели для формализации угроз разработана методика обоснованного выбора дискретных распределений для оценки и управления рисками ИБ, в зависимости от проектных условий и случайных процессов, которая обладает следующей новизной, практической ценностью и теоретической ценностью:

– впервые разработана методика, позволяющая обосновать и формализовать выбор нужного распределения в зависимости от рассматриваемой задачи, типа случайного процесса и статистических свойств;

– развитие методического аппарата в обосновании выбора и применения дискретных распределений в управлении рисками позволит усилить научную базу для построения адаптивных и формализованных моделей защиты;

– ситуационно-обоснованное применение дискретных распределений может помочь специалистам при принятии решений в процессе оценки и прогнозирования риска в условиях неопределенности и ограниченности данных.

В порядке разрешения противоречий между стохастической природой риска, зависящей от параметров дискретного распределения, и необходимостью удерживать его на нужном уровне для обеспечения безопасности системы, были предложены методики регулирования рисков в нужных диапазонах ущерба, позволяющие адаптивно корректировать параметры риска для повышения устойчивости системы, для выбранных дискретных распределений, которые обладают следующей новизной, практической ценностью и теоретической ценностью:

– впервые предложены методики регулирования рисков в нужных диапазонах ущерба, позволяющие адаптивно корректировать параметры риска для повышения устойчивости системы, для выбранных дискретных распределений;

– предложенные методики позволят более эффективно использовать дискретные вероятностные модели в задачах оценки и управления рисками успешности реализации кибератак;

– предложенные методики позволят более эффективно регулировать риски для дальнейшей оценки, позволяющей принять правильное решение и минимизировать ущерб.

СПИСОК ЛИТЕРАТУРЫ

1. Эпидемии в телекоммуникационных сетях / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017.– 284 с. (Серия «Теория сетевых войн»; вып. 1). – Текст: непосредственный.

2. Атакуемые взвешенные сети / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 2). – Текст: непосредственный.

3. Социальные сети и деструктивный контент / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 3). – Текст: непосредственный.

4. Социальные сети и риск-мониторинг / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2019. – 284 с. (Серия «Теория сетевых войн»; вып. 4). – Текст: непосредственный.

5. Социальные сети и психологическая безопасность / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2020. – 284 с. (Серия «Теория сетевых войн»; вып. 5). – Текст: непосредственный.

6. Сетео-информационная эпидемиология / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2021. – 284 с. (Серия «Теория сетевых войн»; вып. 6). – Текст: непосредственный.

7. Картография защищаемого киберпространства / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2022. – 372 с. (Серия «Теория сетевых войн»; вып. 7). – Текст: непосредственный.

8. Организационно-правовая защита сетей / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2023. – 228 с. (Серия «Теория сетевых войн»; вып. 8). – Текст: непосредственный.

9. Остапенко А.Г., Пахомова А.С., Нархов Д.А., Остапенко А.А., Шеншин А.И. Методические основы проектной деятельности при выполнении научно-исследовательской работы студентами специалитета в сфере обеспечения информационной безопасности / А.Г. Остапенко, А.С. Пахомова, Д.А. Нархов, А.А.

Остапенко, А.И. Шеншин // Информация и безопасность. 2020. Т. 23. Вып. 2. С. 191-202. – Текст: непосредственный.

10. Актуальные киберугрозы: IV квартал 2024 года — I квартал 2025 года. – Электрон. дан. – Режим доступа: https://ptsecurity.com/ru-ru/research/analytics/aktualnye-kiberugrozy-iv-kvartal-2024-goda-i-kvartal-2025-goda/#id2. – Текст: электронный.

11. Число кибератак в России и в мире. – Электрон. дан. – Режим доступа:https://www.tadviser.ru/index.php/%D0%A1%D1%82%D0%B0%D1%82%D1%8C%D1%8F:%D0%A7%D0%B8%D1%81%D0%BB%D0%BE_%D0%BA%D0%B8%D0%B1%D0%B5%D1%80%D0%B0%D1%82%D0%B0%D0%BA_%D0%B2_%D0%A0%D0%BE%D1%81%D1%81%D0%B8%D0%B8_%D0%B8_%D0%B2_%D0%BC%D0%B8%D1%80%D0%B5. – Текст: электронный.

12. Остапенко А.А. Методики и алгоритмы риск-анализа успешности реализации массированных кибератак / А.А. Остапенко // Информация и безопасность. 2024. т. 27. Вып. 3. с. 401-420. – Текст: непосредственный.

13. Калашников А.О., Аникина Е.В. Модели управления информационными рисками сложных систем / А.О. Калашников, Е.В. Аникина // Информация и безопасность. 2020. Т. 23. Вып. 2. С. 191-202. – Текст: непосредственный.

14. Калашников А.О., Аникина Е.В. Управление информационными рисками сложной сети на основе метода стохастического имитационного моделирования (часть 1) / А.О. Калашников, Е.В. Аникина // Информация и безопасность. 2019. Т. 22. Вып. 1. С. 6-13. – Текст: непосредственный.

15. Маслова М.А. Научно-методические рекомендации по регулированию рисков нарушения информационной безопасности / М.А. Маслова // Информация и безопасность. 2022. Т. 25. Вып. 4. С. 513-520. – Текст: непосредственный.

16. Ермаков С.А., Каценко Я.М., Болгов А.А., Сафронова В.В., Сибирко К.В. Оценка и регулирование рисков нарушения информационной / С.А. Ермаков, Я.М. Каценко, А.А. Болгов, В.В. Сафронова, К.В. Сибирко // Информация и безопасность. 2020. Т. 23. Вып. 1. С. 107-114. – Текст: непосредственный.

17. Чопоров О.Н., Нежельский Е.Р., Белоножкин В.И., Паринова Л.В. Разработка системы управления рисками организации, подключенной к сети интернет / О.Н. Чопоров, Е.Р. Нежельский, В.И. Белоножкин, Л.В. Паринова // Информация и безопасность. 2018. Т. 21. № 3. С. 290-295. – Текст: непосредственный.

18. Калашников А.О., Аникина Е.В. Управление информационными рисками сложной сети на основе метода стохастического имитационного моделирования (часть 2) / А.О. Калашников, Е.В. Аникина // Информация и безопасность. 2019. Т. 22. Вып. 1. С. 14-21. – Текст: непосредственный.

19. Risk Management. – Электрон. дан. – Режим доступа: https://education.ia.org.hk/tc/index.html. – Текст: электронный.

20. Вишняков Я.Д., Радаев Н.Н. Общая теория рисков_Вишняков / Я.Д. Вишняков, Н.Н. Радаев. – Электрон. дан. – Режим доступа: https://academia-moscow.ru/ftp_share/_books/fragments/fragment_21013.pdf. – Текст: электронный.

21. ГОСТ Р ИСО/МЭК 13335-1 — 2006. Информационная технология. Методы и средства обеспечения безопасности. Часть 1 – Электрон. дан. – Режим доступа: chrome-extension://efaidnbmnnnibpcajpcglclefindmkaj/https://www.altell.ru/legislation/standards/13335-1.pdf. – Текст: электронный.

22. ГОСТ Р ИСО/МЭК 27001 – 2006. Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. – Электрон. дан. – Режим доступа: chrome-extension://efaidnbmnnnibpcajpcglclefindmkaj/https://meganorm.ru/Data/57/5736.pdf. – Текст: электронный.

23. ГОСТ Р ИСО/МЭК 27005 – 2010. Информационная технология. Методы и средства обеспечения безопасности. Менеджмент риска информационной безопасности. – Электрон. дан. – Режим доступа: chrome-extension://efaidnbmnnnibpcajpcglclefindmkaj/https://meganorm.ru/Data/506/50679.pdf. – Текст: электронный.

24. ГОСТ Р ИСО/МЭК 15408-1 – 2008. Информационная технология. Методы и средства обеспечения безопасности. Критерии оценки безопасности

информационных технологий. Часть 1. – Электрон. дан. – Режим доступа: chrome-extension://efaidnbmnnnibpcajpcglclefindmkaj/https://meganorm.ru/Data2/1/4293829/4293829826.pdf. – Текст: электронный.

25. Управление рисками в проекте: как найти и оценить, как составить план защиты от них. – Электрон. дан. – Режим доступа: https://skillbox.ru/media/management/upravlenie-riskami-v-proekte-kak-nayti-i-otsenit-ikh-i-kak-sostavit-plan-zashchity/. – Текст: электронный.

26. Актуальные киберугрозы: III квартал 2024 года. – Электрон. дан. – Режим доступа: https://www.ptsecurity.com/ru-ru/research/analytics/aktualnye-kiberugrozy-iii-kvartal-2024-goda/#id19. – Текст: электронный.

27. Методики и технологии управления информационными рисками. – Электрон. дан. – Режим доступа: https://citforum.ru/security/articles/risk/. – Текст: электронный.

28. Методический документ. Методика оценки угроз безопасности информации. – Электрон. дан. – Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/spetsialnye-normativnye-dokumenty/metodicheskij-dokument-ot-5-fevralya-2021-g. – Текст: электронный.

29. Common Attack Pattern Enumeration and Classification. – Электрон. дан. – Режим доступа: https://capec.mitre.org. – Текст: электронный.

30. ATT&CK Matrix for Enterprise. – Электрон. дан. – Режим доступа: https://attack.mitre.org. – Текст: электронный.

31. OWASP. – Электрон. дан. – Режим доступа: https://owasp.org/. – Текст: электронный.

32. Common Weakness Enumeration. – Электрон. дан. – Режим доступа: https://cwe.mitre.org/data/definitions/693.html. – Текст: электронный.

33. Common Vulnerabilities and Exposures. – Электрон. дан. – Режим доступа: https://www.cve.org/. – Текст: электронный.

34. Волкова Т.А., Волкова С.А., Серебрякова Н.А. Оценка эффективности системы управления рисками / Т.А. Волкова, С.А. Волкова, Н.А. Серебрякова // Вестник ВГУИТ – 2022. №3. с. 326-331. – Текст: непосредственный.

35. Клиниченко М.Ю., Шадиян М.Г. Методы управления кредитным риском для минимизации случаев мошенничества / М.Ю. Клиниченко, М.Г. Шадиян // Учетные записки. 2024. №2. С. 108-113. – Текст: непосредственный.

36. Попов Е.А., Чопоров О.Н., Попова Л.Г., Остапенко О.А. DDoS-атаки на распределенные автоматизированные системы: управление риском при нерегулярном распределении ущерба / Е.А. Попов, О.Н. Чопоров, Л.Г. Попова, О.А. Остапенко // Информация и безопасность. 2014. №4 с. 630-633. – Текст: непосредственный.

37. Пахомова А.С. Метод управления риском информационной безопасности в условиях ведения компьютерной разведки на основе модели жизнеспособности системы / А.С. Пахомова // Информация и безопасность. 2016. №1 с. 122-125. – Текст: непосредственный.

38. Е. Ю. Щетинин, К. М. Назаренко Математические модели и методы оценивания функций распределения экстремальных величин / Е. Ю. Щетинин, К. М. Назаренко. – Электрон. дан. – Режим доступа: http://www1.jinr.ru/Preprints/2003/248(P11-2003-248).pdf. – Текст: электронный.

39. Кудрявцев А.А., Радионов А.В. Введение в количественный риск-менеджмент: учебник / А.А. Кудрявцев, А.В. Родионов. – СПб.: Изд-во С.Петерб. ун-та, 2016. – 192 с.

40. Математическое моделирование рисков: шаманство или кибернетика? – Электрон. дан. – Режим доступа: https://www.securityvision.ru/blog/matematicheskoe-modelirovanie-riskov-shamanstvo-ili-kibernetika/. – Текст: электронный.

41. Корниенко А. А., Корниенко С. В., Глухов А. П., Глухарев М. Л. Риск-модели информационной безопасности» (Риск-модели информационной безопасности : учебное пособие / А. А. Корниенко, С. В. Корниенко, А. П. Глухов, М. Л. Глухарев. — Санкт-Петербург: ПГУПС, 2021. – Электрон. дан. – Режим доступа: https://e.lanbook.com/book/191006. – Текст: электронный.

42. Ланских Ю.В., Ланских В.Г., Родионов К.В. Управление IT-рисками / Ю.В. Ланских, В.Г. Ланских, К.В. Родионов // Учебное пособие. – Текст: непосредственный.

43. Остапенко А.Г., Бурса М.В. Математические основы риск-анализа: учеб. Пособие / А.Г. Остапенко, М.В. Бурса. – Воронеж: ФГБОУ ВПО «Воронежский государственный технический университет», 2013. – Текст: электронный.

44. Оценка рисков информационной безопасности. – Электрон. дан. – Режим доступа: https://mte-cyber.by/mte-blog/information-security-risk-assessment-algorithm/. – Текст: электронный.

45. Риски информационной безопасности. – Электрон. дан. – Режим доступа: https://rt-solar.ru/products/solar_dozor/blog/3320/. – Текст: электронный.

46. Управление рисками информационной безопасности – важнейшая задача. – Электрон. дан. – Режим доступа: https://bosfera.ru/bo/upravlenie-riskami-informacionnoy-bezopasnosti-vazhneyshaya-zadacha?amp. – Текст: электронный.

47. Управление рисками информационной безопасности. – Электрон. дан. – Режим доступа: https://cyberleninka.ru/article/n/upravlenie-riskami-informatsionnoy-bezopasnosti. – Текст: электронный.

48. ГОСТ Р ИСО/МЭК 59516 – 2021. Информационные технологии. Менеджмент информационной безопасности. Правила страхования рисков информационной безопасности. – Электрон. дан. – Режим доступа: https://gostassistent.ru/doc/b49b1430-3843-4021-a73d-a4e671cb273e. – Текст: электронный.

49. ГОСТ Р ИСО/МЭК 58771 – 2019. Менеджмент риска. Технологии оценки риска. – Электрон. дан. – Режим доступа: https://portal.tpu.ru/SHARED/n/NIKOLAENKOVS/student/risk_management/%D0%93%D0%9E%D0%A1%D0%A2%20%D0%A0%2058771-2019%20%D0%9C%D0%B5%D0%BD%D0%B5%D0%B4%D0%B6%D0%BC%D0%B5%D0%BD%D1%82%20%D1%80%D0%B8%D1%81%D0%BA%D0%B0..pdf. – Текст: электронный.

50. Управление рисками информационной безопасности (конспект лекции). – Электрон. дан. – Режим доступа: https://www.securityvision.ru/blog/upravlenie-riskami-informatsionnoy-bezopasnosti-konspekt-lektsii/. – Текст: электронный.

51. ISO/IEC 27102:2019. Менеджмент информационной безопасности. Руководящие указания по киберстрахованию. – Электрон. дан. – Режим доступа: https://cdn.standards.iteh.ai/samples/72436/7ffd160a2a4b4c3c8b91f07956c2b930/ISO-IEC-27102-2019.pdf. – Текст: электронный.

52. Алгоритм оценки риска нарушения информационных сервисов в организации. – Электрон. дан. – Режим доступа: https://cyberleninka.ru/article/n/algoritm-otsenki-riska-narusheniya-informatsionnyh-servisov-v-organizatsii/viewer. – Текст: электронный.

53. Риски информационной безопасности веб-приложений. – Электрон. дан. – Режим доступа: https://habr.com/ru/articles/279219/. – Текст: электронный.

54. Оценка рисков информационной безопасности. Алгоритм. – Электрон. дан. – Режим доступа: https://mte-cyber.by/mte-blog/information-security-risk-assessment-algorithm/– Текст: электронный.

55. Качественные методы оценки риска. – Электрон. дан. – Режим доступа: https://rtmtech.ru/articles/metodika-otsenki-riska/. – Текст: электронный.

56. Калашников А.О., Савенков Г.А. Управление риском неоднородной информационно-телекоммуникационной сети с системой защиты, основанной на ложной информационной системе по стратегии снижения и принятия / А.О. Калашников, Г.А. Савенков // Информация и безопасность. 2016. №1 с. 130-133. – Текст: непосредственный.

57. Управление рисками информационной безопасности в организации. – Электрон. дан. – Режим доступа: https://searchinform.ru/informatsionnaya-bezopasnost/osnovy-ib/osnovnye-aspekty-informatsionnoj-bezopasnosti/osnovnye-printsipy-obespecheniya-ib/upravlenie-informatsionnoj-bezopasnostyu/upravlenie-riskami-informatsionnoj-bezopasnosti-v-organizatsii/. – Текст: электронный.

58. Меры по обеспечению информационной безопасности. – Электрон. дан. – Режим доступа: https://searchinform.ru/informatsionnaya-bezopasnost/osnovy-ib/osnovnye-aspekty-informatsionnoj-bezopasnosti/osnovnye-printsipy-obespecheniya-informatsionnoj-bezopasnosti/mery-po-obespecheniyu-informatsionnoj-bezopasnosti/. – Текст: электронный.

59. Разработка, внедрение систем защиты информации, информационных систем в защищенном исполнении. – Электрон. дан. – Режим доступа: https://acti.ru/resheniya-i-uslugi/informatcionnaia-bezopasnost/bezopasnost-it-infrastruktury/razrabotka-vnedrenie-sistem-zashhity-informaczii-informaczionnyh-sistem-v-zashhishhennom-ispolnenii. – Текст: электронный.

60. Обеспечение соответствия в нормативно-правовой сфере. – Электрон. дан. – Режим доступа: https://www.aspectspb.ru/services/ib/obespechenie-sootvetstviya/. – Текст: электронный.

61. Грачев С.А., Гундорова М.А. Оценка и управление рисками / С.А. Грачев, М.А. Гундорова // Учебное пособие. – Электрон. дан. – Режим доступа: https://dspace.www1.vlsu.ru/bitstream/123456789/8482/1/02022.pdf. – Текст: электронный.

62. Insurance Definition-Insurance and Risk Management. – Электрон. дан. – Режим доступа: https://www.pingan.com/pacms/baoxian/zhishi/97961.jsp. – Текст: электронный.

63. Бойченко О.В. Система управления рисками кибербезопасности кредитно-финансовой деятельности / О.В. Бойченко // Научный вестник: финансы, банки, инвестиции. — 2024. — № 3 (68). — С. 55-65. — ISSN 2312-5330. — Текст : электронный.

64. Дробыш И.И. Современные методы расчета величины Value at Risk при оценке рыночных рисков. / И.И. Дробыш. – Федеральное государственное учреждение «Федеральный исследовательский центр «Информатика и управление» Российской академии наук», г. Москва, Россия. – Текст: электронный.

65. Зачем страховать информационные риски. – Электрон. дан. – Режим доступа: https://www.alfastrah.ru/corporate/imushchestvo-predpriyatiy/kiberstrakhovanie/?utm_referrer=https%3A%2F%2Fwww.google.com%2F. – Текст: электронный.

66. Юзвович Л.И., Дегтярев, Князева Е.Г. Инвестиции: учебник для вузов / Л. И. Юзвович, С.А. Дегтярев, Е. Г. Князева. – Екатеринбург: Изд-во Урал. ун-та, 2016. – 543 с.

67. Менжулин Р.В., Остапенко Г.А., Паринова Л.В. Оценка рисков и регулирование защищенности распределенной платежной системы, на основе банкоматов / Р.В. Менжулин, Г.А. Остапенко, Л.В. Паринова // Информация и безопасность. 2011. №3 с. 359-380. – Текст: непосредственный.

68. Нехайчук Д.В., Адаманова З.О. Киберстрахование в системе риск-менеджмента банковских учреждений / Д.В, Нехайчук, З.О. Адаманова // Учетные записки Крымского инженерного педагогического университета. – 2024. – №1. – Текст: непосредственный.

69. Бойченко О.В. Система управления рисками кибербезопасности кредитно-финансовой деятельности / О.В. Бойченко // Научный вестник: Финансы, банки, инвестиции – 2024 – №3 с. 55-65. – Текст: непосредственный.

70. Сигорский В.П. Математический аппарат инженера / В.П. Сигорский – 2-е изд., стереотип. «Техника 1977. – 768 с.

71. Остапенко Г.А. Методика расчета риска и его параметров для дискретных распределений вероятностей ущерба / Г.А. Остапенко // Информация и безопасность. 2006. №1 с. 124-126. – Текст: непосредственный.

72. Остапенко О.А., Карпеев Д.О., Асеев В.Н., Морев Д.Е., Щербаков В.Б. Риски систем: оценка и управление / О.А. Остапенко, Д.О. Карпеев, В.Н. Асеев, Д.Е. Морев, В.Б. Щербаков; под ред. Ю.Н. Лаврухина, А.Г. Остапенко. – Воронеж: Междунар. ин-т компьют. Технологий, 2007. – 261 с.

73. Паринова Л.В., Радько Н.М., Остапенко А.Г., Каркоцкий В.Л., Плотников Д.Г., Шершень А.Н. К вопросу об оценке рисков атакуемых распределенных информационных систем: развитие математического обеспечения / Л.В. Паринова, Н.М. Радько, А.Г. Остапенко, В.Л. Каркоцкий, Д.Г. Плотников, А.Н. Шершень // Информация и безопасность. 2012. №4 с. 585-586. – Текст: непосредственный.

74. Смолькина Е.Е., Остапенко А.Г., Баранников Н.И., Батаронов И.Л. Аналитические вероятностные модели реализации атак на DNS – серверы / Е.Е. Смолькина, А.Г. Остапенко, Н.И. Баранников, И.Л. Батаронов // Информация и безопасность. 2013. №4 с. 596-603. – Текст: непосредственный.

75. Калашников А.О., Щербаков В.Б., Борисова М.Г., Резов А.А., Ермаков С.А. Оценка и регулирование рисков атакуемых беспроводных сетей при блокировании их элементов / А.О. Калашников, В.Б. Щербаков, М.Г. Борисова, А.А. Резов, С.А. Ермаков // Информация и безопасность. 2017. №2 с. 155-184. – Текст: непосредственный.

76. Дисперсия. – Электрон. дан. – Режим доступа: https://blog.skillfactory.ru/glossary/dispersiya/#:~:text=%D0%94%D0%B8%D1%81%D0%BF%D0%B5%D1%80%D1%81%D0%B8%D1%8F%20%D0%B2%20%D1%81%D1%82%D0%B0%D1%82%D0%B8%D1%81%D1%82%D0%B8%D0%BA%D0%B5%20%E2%80%94%20%D1%8D%D1%82%D0%BE%20%D0%BC%D0%B5%D1%80%D0%B0,%D0%B5%D1%81%D0%BB%D0%B8%20%D1%80%D0%B5%D0%B7%D1%83%D0%BB%D1%8C%D1%82%D0%B0%D1%82%D1%8B%20%D1%81%D0%B8%D0%BB%D1%8C%D0%BD%D0%BE%20%D1%80%D0%B0%D0%B7%D0%BB%D0%B8%D1%87%D0%B0%D1%8E%D1%82%D1%81%D1%8F%20%E2%80%94%20%D0%B2%D1%8B%D1%81%D0%BE%D0%BA%D0%B0%D1%8F. – Текст: электронный.

77. Мультиномиальное распределение зависимых случайных величин. – Электрон. дан. – Режим доступа: http://www.machinelearning.ru/wiki/index.php?title=%D0%9C%D1%83%D0%BB%D1%8C%D1%82%D0%B8%D0%BD%D0%BE%D0%BC%D0%B8%D0%B0%D0%BB%D1%8C%D0%BD%D0%BE%D0%B5_%D1%80%D0%B0%D1%81%D0%BF%D1%80%D0%B5%D0%B4%D0%B5%D0%BB%D0%B5%D0%BD%D0%B8%D0%B5_%D0%B7%D0%B0%D0%B2%D0%B8%D1%81%D0%B8%D0%BC%D1%8B%D1%85_%D1%81%D0%BB%D1%83%D1%87%D0%B0%D0%B9%D0%BD%D1%8B%D1%85_%D0%B2%D0%B5%D0%BB%D0%B8%D1%87%D0%B8%D0%BD. – Текст: электронный.

78. Гипергеометрическое распределение. – Электрон. дан. – Режим доступа:https://cyclowiki.org/wiki/%D0%93%D0%B8%D0%BF%D0%B5%D1%80%D0%B3%D0%B5%D0%BE%D0%BC%D0%B5%D1%82%D1%80%D0%B8%D1%87%D0%B5%D1%81%D0%BA%D0%BE%D0%B5_%D1%80%D0%B0%D1%81%D0%BF%D

1%80%D0%B5%D0%B4%D0%B5%D0%BB%D0%B5%D0%BD%D0%B8%D0%B5. – Текст: электронный.

79. Гипергеометрическое распределение. – Электрон. дан. – Режим доступа:https://ru.wikipedia.org/wiki/%D0%93%D0%B8%D0%BF%D0%B5%D1%80%D0%B3%D0%B5%D0%BE%D0%BC%D0%B5%D1%82%D1%80%D0%B8%D1%87%D0%B5%D1%81%D0%BA%D0%BE%D0%B5_%D1%80%D0%B0%D1%81%D0%BF%D1%80%D0%B5%D0%B4%D0%B5%D0%BB%D0%B5%D0%BD%D0%B8%D0%B5. – Текст: электронный.

80. Геометрическое распределение. – Электрон. дан. – Режим доступа: https://www.yaklass.ru/p/veroyatnost-i-statistika/10-klass/sluchainye-velichiny-i-raspredeleniia-7385679/primery-raspredelenii-v-tom-chisle-geometricheskoe-i-binomialnoe-7446431/re-50be3817-a16d-4af6-9848-3ab462483b30. – Текст: электронный.

81. Попова Е.В., Асеев В.Н., Львович И.Я., Пожидаев С.А. Безопасность компьютерных сетей для дискретного распределения вероятностей ущерба по закону Паскаля / Е.В. Попова, В.Н. Асеев, И.Я. Львович, С.А. Пожидаев // Информация и безопасность. 2006. №2 с. 66-72. – Текст: непосредственный.

82. Попова Е.В., Остапенко А.Г. Чувствительность нормированного риска для величины вероятности ущерба, распределенной по закону Паскаля / Е.В. Попова, А.Г. Остапенко // Информация и безопасность. 2007. №3 с. 503-506. – Текст: непосредственный.

83. Андреев Д.А., Пичугин А.К. Концепция управления рисками информационных атак на основе распределения Пуассона / Д.А. Андреев, А.К. Пичугин // Информация и безопасность. 2008. №3 с. 407-412. – Текст: непосредственный.

84. Аникин И.В., Емалетдинова Л.Ю. Методология количественной оценки и управления рисками информационной безопасности / И.В. Аникин, Л.Ю. Емалдинова // Информация и безопасность. 2016. №4 с. 539-542. – Текст: непосредственный.

85. Остапенко А.А., Шелякин В.П., Е.С. Короткова, А.С. Кривошеин, Д.А. Мальцева, Меркулов П.А., Никитин Н.Д., Титаренко М.О. Оценка критичности

уязвимостей с использованием данных множества риск-калькуляторов / А.А. Остапенко, В.П. Шелякин, Е.С. Короткова, А.С. Кривошеин, Д.А. Мальцева, П.А. Меркулов, Н.Д. Никитин, М.О. Титаренко // Информация и безопасность. 2024. т. 27. Вып. 4. с. 521-542. – Текст: непосредственный.

86. Остапенко Г.А., Казьмин О.А., Субботина Е.В. Неверко В.И. Оценка рисков защищенности компьютерных систем для биномиального дискретного распределения вероятностей ущерба / Г.А. Остапенко, О.А. Казьмин, Е.В. Субботина, В.И. Неверко // Информация и безопасность. 2006. №1 с. 86-91. – Текст: непосредственный.

87. Остапенко А.Г., Тишков С.А. Исследование возможностей регулирования рисков автоматизированных систем при защите от атак типа «Отказ в обслуживании» / А.Г. Остапенко, С.А. Тишков // Информация и безопасность. 2009. №1 с. 25-38. – Текст: непосредственный.

88. Попова Е.В., Остапенко А.Г. Возможные стратегии управления информационными рисками в автоматизированных системах при заданном количестве атак и их успехов / Е.В. Попова, А.Г. Остапенко // Информация и безопасность. 2007. №3 с. 451-456. – Текст: непосредственный.

89. Казьмин О.А., Остапенко А.Г. Исследование риска и защищенности систем для биномиального распределения ущерба / О.А. Казьмин, А.Г. Остапенко // Информация и безопасность. 2007. №3 с. 495-498. – Текст: непосредственный.

90. Фишинг почтовая атака. – Электрон. дан. – Режим доступа: https://www.ibm.com/docs/ru/qradar-common?topic=simulations-phishing-mail-attack. – Текст: электронный.

91. Фишинг (phishing). – Электрон. дан. – Режим доступа: https://www.tadviser.ru/index.php/%D0%A1%D1%82%D0%B0%D1%82%D1%8C%D1%8F:%D0%A4%D0%B8%D1%88%D0%B8%D0%BD%D0%B3_(phishing). – Текст: электронный.

92. Остапенко А.А. Актуальные задачи и некоторые их решения в части риск-калькуляции успешности реализации единичных кибератак / А.А. Остапенко // Информация и безопасность. 2024. №4 с. 543-552. – Текст: непосредственный.

93. Кулаков В.Г., Кобяшев В.Г., Юрочкин А.Г., Остапенко Г.А. Стохастические модели и возможные стратегии информационно-управляющих воздействий в социотехнических системах // В.Г. Кулаков, В.Г. Кобяшев, А.Г. Юрочкин, Г.А. Остапенко // Информация и безопасность. 2006. №1 с. 18-20. – Текст: непосредственный.

94. Остапенко Г.А., Плотников Д.Г., Дуплищева А.Ю. К вопросу об управлении рисками распределенных информационных систем / Г.А, Остапенко, Д.Г. Плотников, А.Ю. Дуплищева // Информация и безопасность. 2010. №2 с. 259-260. – Текст: непосредственный.

95. Остапенко Г.А., Маслихов П.А., Субботина Е.В. Способы регулирования рисков распределенных систем / Г.А. Остапенко, П.А. Маслихов, Е.В. Субботина // Информация и безопасность. 2010. №3 с. 435-438. – Текст: непосредственный.

96. Остапенко Г.А., Транин В.А. Алгоритмическое обеспечение риска-анализа систем в диапазоне ущербов / Г.А. Остапенко, В.А. Транин // Информация и безопасность. 2010. №3 с. 447-450. – Текст: непосредственный.

97. Егоров А.И. Основы теории управления / Егоров А.И. – М: ФИЗМАЛИТ, 2004 – 504 с.

98. Филяк П.Ю., Мильков А.О. Подходы к управлению рисками информационной безопасности для обеспечения защиты информации в организации / П.Ю. Филяк, А.О. Мильков // Информация и безопасность. 2016. №4 с. 583-586. – Текст: непосредственный.

99. Калашников А.О. Управление информационными рисками организационных систем: механизмы активной экспертизы / А.О. Калашников // Информация и безопасность. 2016. №3 с. 307-314. – Текст: непосредственный.

100. Калашников А.О. Управление информационными рисками организационных систем: механизмы аудита / А.О. Калашников // Информация и безопасность. 2016. №3 с. 323-328. – Текст: непосредственный.

101. Калашников А.О. Управление информационными рисками организационных систем: механизмы комплексного оценивания / А.О. Калашников // Информация и безопасность. 2016. №3 с. 315-322. – Текст: непосредственный.

102. Калашников А.О. Управление информационными рисками организационных систем: общая постановка задачи / А.О. Калашников // Информация и безопасность. 2016. №3 с. 36-45. – Текст: непосредственный.

103. Малышенко А.М. Математические основы теории систем / А.М. Малышенко // Учебное пособие. – Томск: Изд-во Томского политехнического университета, 2008. – 364 с. – Текст: непосредственный.